arXiv:2502.14017v2 [cs.CR] 1 Dec 2025

Cyber security of OT networks: A tutorial and survey

Sarthak Kapoor[a], Sumit Kumar[b], Harsh Vardhan[c,*]

[a] *Engineering at Amazon, USA*
[b] *Georgia State University, USA*
[c] *Vanderbilt University, USA*

Abstract

This manuscript explores the cybersecurity challenges of Operational Technology (OT) networks, focusing on their critical role in industrial environments such as manufacturing, energy, and utilities. As OT systems increasingly integrate with Information Technology (IT) systems due to Industry 4.0 initiatives, they become more vulnerable to cyberattacks, which pose risks not only to data but also to physical infrastructure. The study examines key components of OT systems, such as SCADA (Supervisory Control and Data Acquisition), PLCs (Programmable Logic Controllers), and RTUs (Remote Terminal Units), and analyzes recent cyberattacks targeting OT environments. Furthermore, it highlights the security concerns arising from the convergence of IT and OT systems, examining attack vectors and the growing threats posed by malware, ransomware, and nation-state actors. Finally, the paper discusses modern approaches and tools used to secure these environments, providing insights into improving the cybersecurity posture of OT networks.

Keywords: Cyber security, Operational Technology, OT, SCADA, PLC, OT in Healthcare.

1. Introduction

Operational Technology (OT) networks constitute critical infrastructure systems that control physical processes across sectors such as manufacturing, energy, transportation, and utilities. These networks integrate hardware and software components—including Supervisory Control and Data Acquisition (SCADA) systems, Programmable Logic Controllers (PLCs), and Distributed Control Systems (DCS)—to enable safe and efficient industrial operations. The convergence of OT and Information Technology (IT) systems, driven by digitalization and Industry 4.0 initiatives, has substantially expanded the cyber-attack surface of industrial environments [1, 2, 3]. In contrast to conventional IT environments, OT systems exhibit unique cybersecurity challenges due to their reliance on legacy technologies, stringent real-time performance requirements, and the significant operational and financial implications of downtime. Consequently, OT cybersecurity emphasizes the protection of critical infrastructure against threats such as malware, ransomware, and state-sponsored intrusions, while preserving system availability, safety, and reliability [4, 5]. This manuscript provides a comprehensive examination of OT network architectures and their security challenges. It investigates the implications of IT–OT convergence, analyzes attack vectors and recent OT-specific cyber incidents, and reviews contemporary defensive mechanisms and tools. Furthermore, it discusses relevant regulatory frameworks, highlights emerging technological trends in OT security, and evaluates their quantitative impact on industrial resilience.

2. OT and its components

Operational Technology (OT) refers to hardware and software systems used for actuation, sensing and monitoring, computing and control of physical devices, processes, and industrial operations. In this manuscript, the context of OT is in critical sectors including manufacturing, energy, utilities, transportation, and healthcare. The key components and systems in modern OT systems (also called Industrial Control System **ICS**) are as below:

*Corresponding author
Email address: harsh.vardhan@vanderbilt.edu (Harsh Vardhan)

2.1. Supervisory Control and Data Acquisition (SCADA)

Supervisory Control and Data Acquisition (SCADA) systems provide centralized monitoring and high-level control of distributed industrial processes. They collect real-time operational data from geographically dispersed field devices and transmit it to a central control facility, where human operators can supervise, visualize, and, when required, intervene in the process. SCADA systems are extensively deployed in sectors such as power generation and distribution, oil and gas, water and wastewater management, transportation, and manufacturing [6].

System Overview. SCADA integrates sensing, computation, and communication layers for end-to-end process monitoring. The sensing layer captures process variables through field instruments, the control layer executes automation logic via programmable controllers, and the supervisory layer performs centralized data processing, visualization, and archiving. This architecture allows continuous process monitoring, rapid fault detection, and optimization of industrial operations across wide geographic regions.

Core Components. The main components of a SCADA system include field instruments and sensors, Remote Terminal Units (RTUs), Programmable Logic Controllers (PLCs), communication infrastructure, a master station with Human–Machine Interface (HMI), and a data historian.

Field instruments and sensors measure parameters such as temperature, pressure, flow rate, or rotational speed and generate continuous feedback for process control. Remote Terminal Units (RTUs) are microprocessor-based devices that interface with sensors, digitize analog signals, and relay data to the control center via long-distance communication channels including cellular, radio, satellite, or Ethernet links [7]. Programmable Logic Controllers (PLCs) are industrial digital controllers responsible for executing deterministic logic in real time. They operate cyclically—scanning inputs, running control logic, and updating outputs within milliseconds—to ensure reliable process actuation. PLCs are typically programmed according to the IEC 61131-3 standard using languages such as Ladder Logic, Function Block Diagram, or Structured Text. Communication infrastructure forms the backbone interconnecting RTUs, PLCs, and the supervisory layer. Depending on the application, it may employ wired Ethernet, serial interfaces (RS-232/RS-485), or wireless networks. The SCADA master station serves as the central supervisory node that aggregates data, issues commands, and presents system status through the HMI. Finally, the data historian archives time-stamped process information for trend analysis, reporting, and compliance auditing. Typical data records include tag identifiers, timestamps, measured values, quality indicators, and event or alarm metadata.

Operational Workflow. In operation, field sensors capture process data, which RTUs and PLCs preprocess and forward through the communication network to the master station. Operators monitor key indicators on HMI displays and may dispatch control commands or re-parameterize local controllers as needed. The historian continuously logs data for performance analysis and predictive maintenance. This closed-loop interaction enables both automated and human-supervised control of industrial assets while maintaining safety and availability.

Further implementation details—such as PLC hardware architecture, memory organization, communication interfaces, and electrical isolation mechanisms—are provided in **Appendix A** for reference.

2.2. Distributed Control Systems (DCS)

Distributed Control Systems (DCS) decentralize control across subsystems to enhance reliability and performance and are common in chemical plants, oil refineries, and large-scale production facilities. Supervisory Control and Data Acquisition (SCADA) systems and Distributed Control Systems (DCS) are both integral parts of industrial automation and control systems. While they share some similarities, they are designed for different purposes and have distinct architectures and applications. SCADA is primarily designed for high-level supervisory management and control. It is used to monitor and control processes that are distributed over large geographical areas. SCADA systems are commonly used in industries such as water and wastewater management, oil and gas pipelines, electrical power distribution, and telecommunications. DCS (Distributed Control System) is primarily designed for process control within a localized area, such as a single plant or factory. DCS systems are used for continuous and complex processes where control and monitoring are needed in a confined area. They are commonly found in industries such as chemical processing, petrochemical, oil refining, and power generation.

2.2.1. Key Differences

1. System Architecture: SCADA typically has a centralized architecture where a central master station collects data from Remote Terminal Units (RTUs) and Programmable Logic Controllers (PLCs) distributed across various locations. The communication is often event-driven or poll/response-based. It emphasizes remote monitoring and control, with a focus on data acquisition and human-machine interface (HMI). DCS employs a distributed architecture where control is decentralized, and various controllers communicate with each other directly. The communication is often continuous and deterministic. It emphasizes process control and automation with local control loops, extensive inter-controller communication, and high reliability.

2. Geographical scope: SCADA is designed for large-scale applications with wide geographical distribution. It is ideal for systems like water distribution networks, oil and gas pipelines, and power grids. DCS, on other hand, is designed for localized applications within a single plant or facility. It is ideal for controlling complex industrial processes within a confined area.

3. Control Approach: In SCADA, supervisory control with decision-making often done at the central control room. Local controllers like RTUs and PLCs perform basic control functions and relay data to the central system. However, in DCS, distributed control with decision-making is distributed across multiple controllers. Each controller can execute complex control algorithms independently, enhancing system reliability and responsiveness.

4. System Complexity and Scalability: SCADA is more scalable in terms of geographical reach but might have limitations in handling very complex control processes. DCS is more complex in terms of control capabilities but typically confined to a single site or plant, making it less scalable geographically.

5. Example Application: SCADA is mainly used in water and wastewater management, oil and gas pipelines, electrical power distribution, telecommunication systems. DCS is mainly deployed in chemical processing plants, petrochemical and oil refineries, power generation plants, food and beverage processing.

SCADA systems are best suited for applications that require remote monitoring and control over vast geographical areas, emphasizing data acquisition and human interaction. DCS systems are ideal for complex, localized process control within a single plant, emphasizing automated control and process optimization.

2.3. Communication protocols in OT devices

There are several communication protocols used in industrial automation and process control each with its own unique features and applications. Here are some of the most common ones:

1. Profibus (Process Field Bus): It has two major variant- Profibus DP (Decentralized Peripherals) and Profibus PA (Process Automation). It features High-speed communication, real-time data exchange, and extensive diagnostics capabilities. It is mainly used for connecting field devices like sensors and actuators in manufacturing and process automation.

2. Profinet (Process Field Network): It is an Ethernet-based protocol offering real-time data transmission, extensive diagnostics, and flexibility for integrating IT systems with automation systems. It is used in industrial automation, particularly where high-speed communication and integration with enterprise systems are required.

3. Ethernet/IP (Ethernet Industrial Protocol): It uses standard Ethernet for industrial applications, supports real-time control and data acquisition, extensive device support. It is widely used in factory automation, including robotics, assembly lines, and material handling systems.

4. CANopen (Controller Area Network): It is designed for embedded systems with a focus on real-time data exchange, supports network management and device configuration.It is mainly used in automotive systems, medical equipment, industrial machinery, and building automation.

5. DeviceNet: It is based on CAN (Controller Area Network), DeviceNet supports real-time data exchange, device configuration, and diagnostics. It is used primarily in industrial automation for connecting sensors and actuators to controllers.

6. HART (Highway Addressable Remote Transducer): It combines analog and digital communication, allows two-way communication over existing 4-20 mA analog wiring. It is used extensively in process industries for device diagnostics, configuration, and data acquisition.

7. BACnet (Building Automation and Control Network): It is an open protocol designed for building automation and control systems, supports various types of data transmission (e.g., alarm, event, trend data). It is mainly used in HVAC, lighting, security, and fire detection systems in building automation.

8. DNP3 (Distributed Network Protocol): it is designed for reliable, secure communication in SCADA systems, supports complex data structures and time-stamped data. It is mainly used in Electric utility industry, water and wastewater systems, oil and gas pipelines.

9. SERCOS (Serial Real-time Communication System): It is high-speed, deterministic communication, designed for motion control systems. It is mainly used in CNC machines, robotics, and other motion control applications.

10. Modbus: It is a widely-used communication protocol in the field of process automation and SCADA (Supervisory Control and Data Acquisition). It allows various devices and equipment to communicate with each other effectively. Modbus was initially developed by Modicon (now owned by Schneider Electric) in 1979 and has become a standard in the industry due to its openness and versatility. It facilitates the exchange of information between electronic devices. It is especially prevalent in process automation and SCADA systems. Devices such as temperature and humidity sensors can use Modbus to send data to supervisory computers or PLCs (Programmable Logic Controllers).

2.3.1. Types of Modbus Communication:

Several versions of the Modbus protocol exist, including:

(a) Modbus RTU (Remote Terminal Unit):It uses binary representation and is optimized for fast communication.

(b) Modbus ASCII: It uses ASCII characters for communication, making it human-readable but slower compared to RTU.

(c) Modbus TCP: It utilizes TCP/IP over Ethernet, allowing Modbus to be used in modern network infrastructures.

(d) Modbus Plus: A high-speed, peer-to-peer protocol with token-passing capabilities.

2.3.2. Modbus messaging Architecture

Modbus operates on a master/slave architecture (client/server for Ethernet). Master Device initiates transactions (queries) and can address individual slaves or broadcast messages to all slaves. Slave device responds to the master's queries with the requested data or actions. Slaves do not initiate messages. Message Structure consists of a slave address, function code, data, and error-checking field. Error Checking ensures data integrity by validating message contents.

2.3.3. Physical Media

Modbus can communicate over various physical media, including:

(a) RS-232: Original interface, limited to short distances and point-to-point communication.

(b) RS-485: Supports longer distances, higher speeds, and multiple devices on a single network.

(c) Ethernet (TCP/IP): Allows Modbus messages to be embedded in Ethernet packets, supporting mixed protocols on the same network.

Being an open standard, and freely available, there is widespread adoption. It also supports multiple communication types and physical media. It also facilitates integration of devices from different manufacturers, enhancing flexibility and choice.

Each of these protocols has its own strengths and is chosen based on the specific requirements of the application, such as speed, reliability, real-time capabilities, and the types of devices being integrated.

Protocol	Description	Common Applications
Profibus	High-speed communication with real-time data exchange, extensive diagnostics. Two variants: Profibus DP (Decentralized Peripherals) and Profibus PA (Process Automation).	Used for connecting field devices like sensors and actuators in manufacturing and process automation.
Profinet	Ethernet-based protocol offering real-time data transmission and integration with IT systems.	Used in industrial automation where high-speed communication and integration with enterprise systems are required.
Ethernet/IP	Uses standard Ethernet for industrial applications, supports real-time control and data acquisition.	Widely used in factory automation, including robotics, assembly lines, and material handling systems.
CANopen	Designed for real-time data exchange in embedded systems, supports network management and device configuration.	Used in automotive systems, medical equipment, industrial machinery, and building automation.
DeviceNet	Based on CAN (Controller Area Network), supports real-time data exchange, device configuration, and diagnostics.	Primarily used in industrial automation for connecting sensors and actuators to controllers.
HART	Combines analog and digital communication over existing 4-20 mA analog wiring, supports two-way communication.	Extensively used in process industries for device diagnostics, configuration, and data acquisition.
BACnet	Open protocol for building automation and control systems, supports various types of data transmission.	Used in HVAC, lighting, security, and fire detection systems in building automation.
DNP3	Designed for secure communication in SCADA systems, supports complex data structures and time-stamped data.	Commonly used in electric utilities, water and wastewater systems, and oil and gas pipelines.
SERCOS	High-speed, deterministic communication protocol designed for motion control systems.	Used in CNC machines, robotics, and other motion control applications.
Modbus	Widely-used protocol for process automation and SCADA systems, with several versions including Modbus RTU, ASCII, TCP, and Plus.	Facilitates communication between devices in process automation and SCADA systems, such as temperature sensors, PLCs, and supervisory computers.

Table 1: Communication Protocols Used in OT Devices

2.4. An example Industry model with SCADA and its components

The figure 1 illustrates a mixing process plant controlled through an Operational Technology (OT) network, highlighting the integration of Programmable Logic Controllers (PLCs), Remote Terminal Units (RTUs), and SCADA (Supervisory Control and Data Acquisition) systems. The process begins with the monitoring of critical parameters, such as temperature and RPM, via sensors attached to components like the furnace and centrifuge pump. These values are fed into the PLCs, which manage the control systems, including voltage control and motor operations, ensuring optimal function. The mixing vessel, where items are combined, is controlled by the motor and further monitored through various sensors. The entire system is supervised and controlled through SCADA stations, which communicate with the RTUs and collect historical data for future analysis. Electrical power distribution is shown in red, while OT-based communication flows are represented in green.

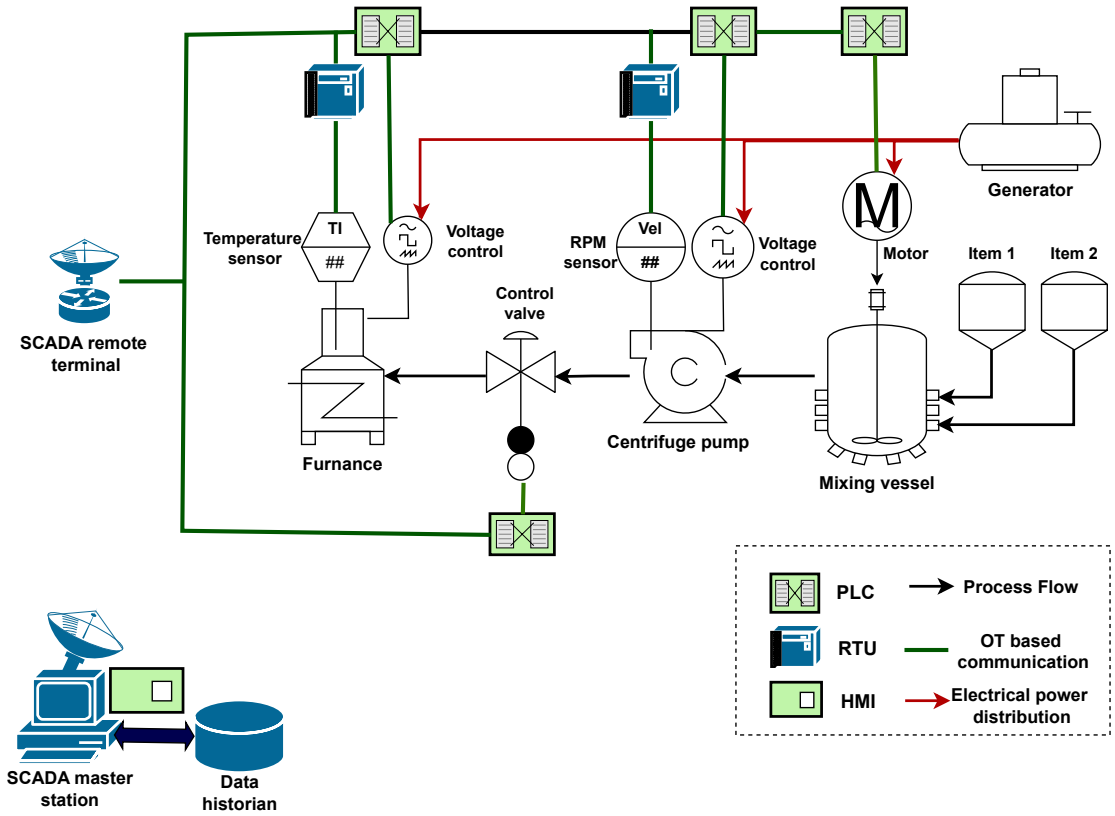

Figure 1: An example mixing processing plant with the OT network and PLC based controller with SCADA station.

3. Attacks on OT devices: A glance

3.1. IT and OT overlap: An attack path

The convergence of Information Technology (IT) and Operational Technology (OT) has brought significant benefits to industries, including improved efficiency, better data analysis, and enhanced decision-making. However, it has also introduced new cyber security challenges.

By Information Technology (IT), we refer to systems used for data-centric computing. Examples are Computers, servers, enterprise applications, networking hardware. On the other hand, Operational Technology (OT) includes hardware and software that detects or causes changes through direct monitoring and control of physical devices, processes, and events. Examples are Industrial control systems (ICS), SCADA systems, PLCs, sensors etc. Modern industrial environments increasingly integrate IT systems with OT

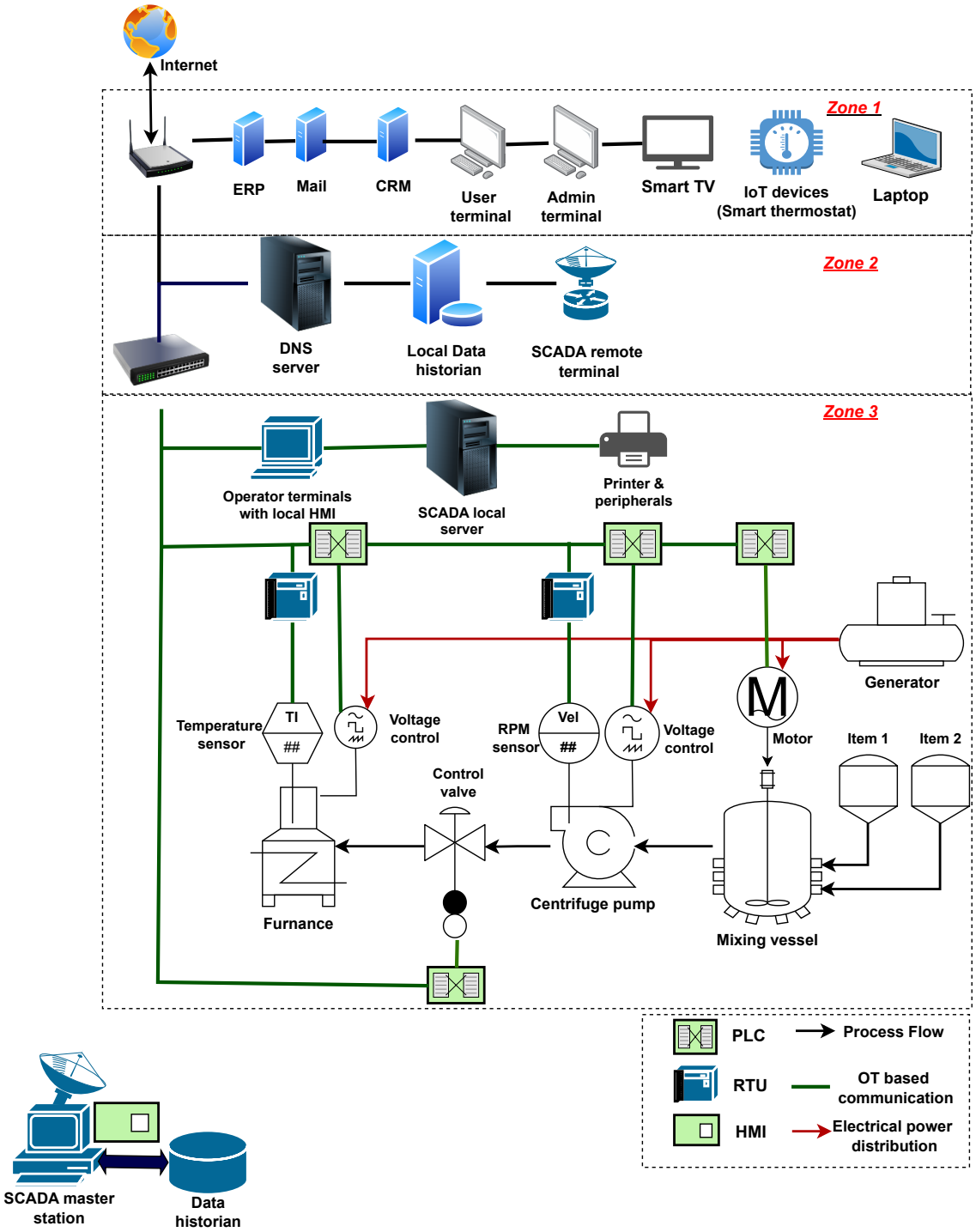

Figure 2: Example IT–OT network architecture. Zone 1 represents the IT network, Zone 2 is the IT–OT bridge, and Zone 3 represents the OT network.

systems. Although IT/OT convergence leads to improved monitoring, data collection, and automation of industrial processes it raises the cyber security concerns in OT networks. There are various attack vectors.

Some of them are listed as below:

1. Phishing and Social Engineering: Attackers use social engineering to gain initial access to IT networks, which can then be used as a pivot point to OT systems. A common example is Spear phishing emails targeting employees with access to both IT and OT systems.

2. Exploits: Vulnerabilities in IT network components (e.g., routers, firewalls, softwares running on IT devices) can be exploited to access OT networks. Examples are exploiting unpatched network devices that bridge IT and OT environments, or exploiting a version of installed software to gain foothold in the network.

3. Malware injection: Once an IT node is compromised, attackers move laterally to gain a foothold in the OT network. Then, malware specifically designed to target OT systems is planted. Examples are Stuxnet worm, which targeted SCADA systems via infected USB drives.

4. Supply Chain Attacks: Compromised third-party software or hardware can introduce vulnerabilities into both IT and OT systems. Examples are Infected updates or compromised software from vendors.

5. Insecure Remote Access: Remote access solutions used for monitoring and controlling OT systems can be exploited if not properly secured. Examples are weak credentials or unencrypted remote access connections.

3.2. Security Considerations for IT-OT Systems

Given the critical nature of OT systems, their security is paramount. Here are some key security considerations that can be segregated in two parts, first the concerns that arises in IT network and second, the concerns that are in OT networks:

3.2.1. Security Concerns in IT networks

1. Network Segmentation: Isolating the SCADA network from other networks to reduce the risk of cyber-attacks. Implement robust network segmentation between IT and OT networks can limit the impact of a potential breach. It can be done by using firewalls, VLANs, and DMZs to create isolated network zones. Example commercial firewalls are Cisco ASA, Palo Alto Networks, Fortinet, while open source firewalls are pfSense, OPNsense, IPFire. IPFire is an open-source firewall distribution based on Linux, designed for ease of use and high performance. For implementing VLANs (Virtual Local Area Networks) using open-source solutions, Linux has built-in support for VLANs through the vlan kernel module and the ip command from the iproute2 package. This method is highly flexible and allows for detailed VLAN configuration. Netplan is a utility for easily configuring networking on a Linux system, specifically on Ubuntu. The DMZs are Implemented using network firewalls and segmentation strategies.

2. Access Control: It refers to implementing strict access controls to ensure that only authorized personnel can access the system. In practice, this approach emphasizes enforcement of strict access controls and least privilege principles for users with access to both IT and OT systems. It is also recommended to regularly review and audit access rights. Linux uses a traditional UNIX-like permission model that includes read (r), write (w), and execute (x) permissions for three categories of users: the file owner, the group, and others. Access Control Lists (ACLs) is another mechanism that provide a more flexible permission mechanism by allowing you to set permissions for individual users or groups beyond the owner, group, and others. Identity and Access Management (IAM) tools like Okta, Microsoft Azure Active Directory, Role-325 Based Access Control (RBAC) Implemented through Active Directory are also widely used.

3. Regular Updates and Patching: Keeping the system updated with the latest security patches to mitigate vulnerabilities. Patch Management Tools:** WSUS, SCCM, Ivanti Patch for Windows;319 Ansible, Puppet for Linux. - **Vulnerability Management:** Tenable Nessus, Qualys, Rapid7 Nexpose.

4. Monitoring and Detection: - Deploy advanced monitoring and intrusion detection systems (IDS) to identify suspicious activities in real-time. - Use Security Information and Event Management (SIEM) systems to correlate events from IT and OT systems. Deploying Intrusion Detection Systems (IDS)

and Intrusion Prevention Systems (IPS) to monitor network traffic for suspicious activity are essential components of network security. IDS is designed to monitor network traffic and alert administrators about potential security breaches, attacks, or policy violations. IPS not only detects but also prevents potential security breaches by taking action based on pre-defined rules. Both can work either on network-based or host-based. Some famous open-source IDS/IPS are Snort, Suricata, OSSEC, Bro/Zeek. Other tools that can be helpful are - Log Management Tools like Graylog (open-source log management tool that provides real-time log analysis and monitoring with features like Centralized log management, real-time search, customizable dashboards, alerting) , Forensic Analysis Tools (Autopsy- An open-source digital forensics platform for analyzing hard drives and smartphones with features like File system analysis, timeline analysis, keyword search, multimedia analysis) are all deployed and useful. SIEM (Security Information and Event Management) Tools (like Splunk with features like Event correlation, log management, compliance reporting etc), Endpoint Detection and Response (EDR) Tools (like CrowdStrike Falcon, Microsoft Defender with features like Endpoint monitoring, behavioral analysis, automated investigation and response etc.) , Network Traffic Analysis Tools (like wireshark, zeek with features like Deep packet inspection, real-time capture, customizable filters, extensive protocol support, event-driven scripting).

5. Incident Response: Develop and test comprehensive incident response plans that cover both IT and OT environments. Include specific procedures for isolating and mitigating OT system attacks.

   Establishing a plan for responding to security incidents to minimize damage and recover quickly is also an essential component. Incident Response management Tools like the TheHive (open-source tool with features like Case management, collaboration, automated workflows, integration with threat intelligence.),

6. Training and Awareness: - Conduct regular cybersecurity training for employees, focusing on the unique challenges of IT/OT convergence. - Promote a culture of security awareness and vigilance.

7. Secure Configuration: - Apply security best practices for configuring both IT and OT systems. - Regularly review and update security configurations to address emerging threats. Using encryption for data transmission to protect against eavesdropping and data tampering.

3.2.2. Security considerations in OT networks

Programmable Logic Controllers (PLCs) and other equipment shares some common vulnerabilities related to PLC standards and implementations:

1. Insecure Communication Protocols : Many industrial communication protocols used by PLCs, such as Modbus, DNP3, and EtherNet/IP, were not designed with security in mind. These protocols often lack encryption, authentication, or integrity checks, making them vulnerable to Eavesdropping (Attackers can intercept unencrypted traffic), Man-in-the-Middle (MitM) Attacks (attackers can modify communication between the PLC and control systems) and replay Attacks (legitimate commands can be captured and replayed later by an attacker). There are protocols with built-in encryption and authentication (e.g., OPC UA, TLS), It needs to be adapted for making communication more robust and secure[8].

2. Weak Patch Management: Industrial systems are often patched infrequently due to operational concerns, leaving known vulnerabilities unaddressed for extended periods or delayed patch or incomplete patching. Legacy PLCs may no longer receive security updates, making them permanently vulnerable. Regularly apply security patches and updates, even in industrial environments requires patch management tools specific to OT networks. Currently these tools are not widely available.

3. Inadequate Authentication Mechanisms: Many PLCs ship with default credentials that are rarely changed. Attackers can use these credentials to gain unauthorized access. These are due to lack of knowledge and awareness to the personnel working in OT environment , who are less aware to these attacks. Some PLCs use weak or easily guessable passwords, making brute-force attacks feasible.

4. Firmware Vulnerabilities: Some PLCs allow firmware updates without verifying the authenticity of the firmware, enabling attackers to inject malicious code. Some manufacturers unintentionally include backdoors in their firmware, providing attackers with hidden access (example firmware occurred with Siemens' S7-1200 and S7-1500 PLCs in 2013. Siemens included a special "engineering mode" in the firmware, designed to allow factory engineers and service technicians to access the PLC in case of emergencies or maintenance needs. While this feature was convenient for Siemens personnel, it effectively functioned as a backdoor, allowing privileged access to the PLC, bypassing regular authentication measures. [9].

5. Lack of Secure Boot: Insecure Boot Processes: Some PLCs do not implement secure boot processes, allowing attackers to modify bootloaders or the operating system, potentially leading to persistent compromises.

6. Weak Access Control: Lack of Role-Based Access Control (RBAC) - PLCs often lack fine-grained access control mechanisms, allowing unauthorized users to perform critical operations. Insufficient Audit Logs: Some PLCs lack proper logging, making it difficult to detect and respond to unauthorized access or actions.

7. Side-Channel Attacks: Attackers may exploit side-channel attacks, such as power consumption or timing data, to extract information from a PLC or influence its operation.

In recent years, attacks on Programmable Logic Controllers (PLCs) have become more sophisticated, targeting critical infrastructure and industrial control systems (ICS). Here are some example attacks on OT network or devices:

1. Stuxnet: Stuxnet was one of the first highly sophisticated worm that specifically targeted Siemens PLCs used in Iran's nuclear facilities [10]. The worm infected Windows computers and then targeted Siemens Step7 software running on programmable logic controllers (PLCs) to reprogram it, causing the centrifuges to spin out of control while reporting normal operations to operators [11]. Stuxnet exploited four zero-day vulnerabilities in Microsoft Windows to spread and infect systems. Zero-day vulnerabilities are previously unknown and unpatched flaws in software. The worm spread via removable USB drives, exploiting the autorun feature to execute itself when the drive was connected to a computer. It also spread through network shares and used a variety of techniques to escalate privileges and gain administrative access on infected machines. Once inside a network, Stuxnet searched for Siemens Step7 software and PLCs and injected malicious code into the PLCs, which allowed it to manipulate the industrial processes they controlled. The worm targeted specific models of Siemens PLCs that controlled centrifuges used for uranium enrichment. The worm had sophisticated rootkit capabilities that allowed it to hide its presence on infected systems[12]. It intercepted and altered communication between the PLCs and the monitoring software, ensuring that operators remained unaware of the sabotage. It subtly altered the speeds of the centrifuges, causing them to spin at dangerous levels and ultimately leading to physical damage, while reporting normal operations to the monitoring systems. It caused significant damage (approximately 1,000 centrifuges) to Iran's nuclear program, showcasing the potential for cyber-physical sabotage [13]. Stuxnet demonstrated the potential for cyber weapons to achieve strategic military objectives and set a precedent for the development of Advanced Persistent Threats (APTs) [14] that target critical infrastructure.

2. Industroyer/CrashOverride (2016): Industroyer [15] targeted Ukraine's power grid, causing widespread outages. The malware included modules to control industrial processes via ICS protocols, including IEC 104, IEC 61850, and OPC, to manipulate switches and circuit breakers [16]. These protocols are used in industrial control systems (ICS) for telecontrol and telemonitoring operate over TCP/IP networks. The malware uses a backdoor to maintain persistent access to the compromised network. This backdoor allows the attackers to issue commands to the infected systems remotely. To cover its tracks and hinder recovery efforts, Industroyer contains a data wiper module that erases crucial system files, rendering the infected systems inoperable. The initial infection vector for Industroyer is not fully known, but it is believed to have involved spear-phishing emails or other social engineering techniques to gain an initial foothold in the target network [17]. Industroyer's payload modules are capable of communicating

directly with ICS protocols, enabling the malware to send malicious commands to industrial equipment, such as opening circuit breakers to disrupt power flow [18]. The attack caused a power outage in parts of Kiev, affecting tens of thousands of residents for about an hour. It demonstrated the capability to disrupt critical infrastructure by directly interacting with PLCs and other ICS components.

3. Triton/Trisis (2017): Triton malware targeted Schneider Electric's Triconex safety instrumented systems (SIS) used in critical infrastructure [19]. Triton was discovered in 2017 after it was used to attack a petrochemical plant in Saudi Arabia. Triton consists of several modules that interact with the Triconex SIS controllers [20]. These modules are capable of reading and writing to the controllers. It aimed to reprogram SIS controllers to either shut down operations or cause unsafe conditions. The malware installs a backdoor on the compromised system, allowing remote operators to execute commands and manipulate the SIS devices. Triton includes an execution framework that ensures the payload is delivered and executed on the target devices, and it can persist across reboots. The initial infection vector for Triton remains unclear, but it is believed to involve compromising the engineering workstation connected to the SIS network. Once inside the network, the attackers use various techniques to move laterally and gain access to the SIS controllers. It highlighted the risk of attacks on safety systems designed to prevent catastrophic failures in industrial environments.

4. EKANS Ransomware (2020): EKANS (also known as Snake) is a type of ransomware that specifically targets OT systems. First discovered in December 2019, EKANS is notable for its focus on operational technology (OT) environments, including those in the manufacturing, energy, and healthcare sectors. The EKANS (or Snake) ransomware employs several specific attack methods that are particularly targeted towards disrupting OT Systems. The initial access and deployment is conducted by through phishing emails (these emails are designed to trick users into downloading and executing the ransomware payload) that contain malicious attachments or links, exploit known vulnerabilities in public-facing applications or systems (this could involve exploiting unpatched software, misconfigured servers, or using brute force attacks against weak passwords) or exploit weak or exposed Remote Desktop Protocol (RDP) configurations to gain remote access to the targeted network. Once inside the network, attackers map the network to identify critical systems and assets. This helps them understand the layout and identify the most valuable targets. Attackers gather credentials to escalate privileges and move laterally within the network. This can involve techniques like keylogging, credential dumping, and exploiting password reuse. Attackers often use legitimate administrative tools and protocols (like PowerShell, PsExec, and WMI) to move laterally within the network, making detection harder. Attackers establish persistence on critical systems to ensure they can maintain access even if some initial footholds are detected and removed. EKANS includes a predefined list of processes and services that are typically associated with ICS environments. The ransomware attempts to terminate these processes to disrupt operations. The kill list can include processes related to control systems, data historians, and other OT applications. By terminating ICS-related processes, EKANS aims to cause operational disruptions, halt production lines, and create chaos within industrial environments. EKANS encrypts files on the infected systems using strong encryption algorithms. The ransomware leaves a ransom note on the infected systems, demanding payment in exchange for the decryption key. Honda reported a cyberattack that led to the temporary suspension of production at several manufacturing plants. While Honda did not confirm EKANS specifically, cybersecurity experts suggested that the attack bore similarities to EKANS tactics.

5. PLC-Blaster (2020): PLC-Blaster is a worm that specifically targets Programmable Logic Controllers (PLCs). PLC-Blaster is designed to spread across networks, infecting other PLCs connected to the same network. This makes it particularly dangerous in large industrial environments where many PLCs are networked together. PLC-Blaster exploits vulnerabilities in the PLC firmware or network configuration to gain access and spread. The worm can also steal credentials to facilitate its spread across the network. Once a PLC is infected, PLC-Blaster autonomously scans the network for other vulnerable PLCs and spreads without human intervention. The worm employs techniques to evade detection by security systems, making it harder for traditional antivirus and intrusion detection systems to identify and stop it. The initial foothold of PLC-Blaster involves several potential methods to infiltrate a network and infect the first Programmable Logic Controller (PLC). Attackers does start the exploit vulnerabilities

in the PLC's firmware. Many PLCs run outdated or unpatched firmware that contains security flaws, providing an entry point for the worm. Vulnerabilities in software used to manage or communicate with PLCs, such as Human-Machine Interfaces (HMIs) or Supervisory Control and Data Acquisition (SCADA) systems, can also be targeted. Penetration through IT network vulnerabilities like phishing, compromised network devices and remote access exploitation.

Name of Attack	**Affected Sector/-Plant**	**Initialization**	**Mode of Operation**
Stuxnet	Nuclear Enrichment Facilities (Iran)	Infected USB drives exploited vulnerabilities in Windows	Targeted Siemens PLCs controlling uranium centrifuges, manipulated PLC logic to cause centrifuges to spin at destructive speeds while hiding the malicious behavior from monitoring systems.
Industroyer	Power Grid (Ukraine)	Likely through spear-phishing or social engineering	Interacted with ICS protocols (IEC 104, IEC 61850) to send malicious commands to control circuit breakers, causing temporary power outages in Kiev.
Triton/Trisis	Petrochemical Plant (Saudi Arabia)	Compromised engineering workstation	Targeted Schneider Electric's Triconex safety systems, attempting to reprogram them, potentially causing dangerous conditions or shutdowns of critical safety mechanisms in industrial operations.
EKANS (Snake) Ransomware	Manufacturing, Energy, Healthcare	Phishing emails or weak RDP configurations	Terminated ICS processes and encrypted files in OT environments, causing operational disruption. Aimed to halt production lines and demand ransom for decryption of essential OT systems and files.
PLC-Blaster	Industrial Automation (PLCs)	Exploited vulnerabilities in PLC firmware or through IT network	Spread across networks autonomously, infecting connected PLCs. It stole credentials and leveraged them to propagate, targeting vulnerabilities in PLC firmware and software to disrupt operations.

Table 2: Summary of some recent cyberattacks on OT systems

4. Emerging Trends in OT Cybersecurity

As industrial environments continue to evolve, the emergence of new cybersecurity trends provides robust solutions to address vulnerabilities in OT systems. These trends leverage advanced technologies such as artificial intelligence (AI) [21], blockchain [22], and digital twins [23], improving the security posture of OT networks while addressing the unique challenges of IT-OT convergence. With OT systems playing critical roles in sectors such as manufacturing, energy, and transportation, the integration of these innovations is essential to protect against increasingly sophisticated cyber threats.

Unlike traditional IT networks, OT systems must balance real-time operational requirements, legacy infrastructure, and stringent uptime demands, which complicates their cybersecurity needs. Emerging technologies address these challenges by enabling real-time threat detection, improving incident response efficiency, and improving system resilience. For example, AI models trained on historical sensor data can predict anomalies in industrial processes [24], while blockchain ensures tamper-proof logging of system events [25].

Similarly, digital twins allow organizations to simulate cyberattack scenarios [26], providing insight into vulnerabilities without disrupting live operations.

Moreover, with the convergence of IT and OT systems through Industry 4.0 initiatives, cybersecurity measures must now account for an expanded attack surface [27]. Emerging trends focus on addressing vulnerabilities stemming from insecure legacy protocols, insufficient authentication mechanisms, and increased reliance on resource-constrained IoT devices. By adopting these advanced technologies, organizations can improve the reliability, safety, and resilience of their critical infrastructure, ensuring operational continuity in the face of evolving cyber threats. Below emerging trends demonstrate how innovative technologies are addressing the evolving challenges of OT cybersecurity, offering practical solutions for securing critical infrastructure. As these technologies mature, their adoption across industries will be pivotal in enhancing the safety and reliability of OT systems.

4.1. AI and ML for Threat Detection and automated Cyber defense

AI and ML are transforming industries by enabling automation, intelligence, and efficiency. In self-driving cars, AI and ML power real-time sensor fusion, object detection, and route optimization, ensuring safer and more efficient autonomous navigation. In underwater vehicle design [28][29] [30], they enhance autonomous operation by optimizing sensor placement, improving environmental adaptation, and enabling intelligent decision-making for deep-sea exploration. In healthcare, AI-driven Computer-Aided Diagnosis is revolutionizing medical imaging, detecting diseases like malaria with higher accuracy [31] and speed, assisting doctors in early diagnosis and treatment planning.

In the energy sector, it also holds boundless potential, enhancing power grid management through real-time monitoring and adaptive load balancing, improving renewable energy forecasting for better integration of solar and wind power, and enabling predictive maintenance in oil and gas to minimize downtime and operational risks. In recent years, it has also been utilized to strengthen cybersecurity in OT networks, analyzing vast real-time data from sensors, PLCs, and SCADA systems to enable anomaly detection and predictive threat modeling, helping prevent cyber threats before they escalate. Duke Energy, a major power utility in the US, has deployed ML models to analyze sensor data from its power grid [32]. These models detect deviations in parameters such as voltage and frequency, flagging potential cyberattacks or equipment failures before they occur. This approach has significantly improved the reliability and safety of its energy distribution systems. According to a 2023 article, Duke Energy's hybrid model of engineered analytics and ML has proven to be an excellent but imperfect tool — more accurate than either pure AI/ML tools or engineered analytics alone [33]. AI is also being used in predictive maintenance [34], where abnormal vibration data from turbine sensors is analyzed to forecast equipment failures, minimizing downtime and reducing costs [35].

4.2. Zero Trust Architecture in OT Systems

Zero Trust Architecture (ZTA) principles, which enforce continuous verification of identity and access at every network segment, are now being adapted to OT environments [36]. This approach ensures that access to critical OT systems is restricted based on roles and credentials, significantly reducing the risk of unauthorized activities.

Siemens has integrated ZTA into its industrial automation products, implementing strict role-based access control (RBAC) [37] and multi-factor authentication in SCADA and PLC systems. For instance, Siemens' SIMATIC controllers now include access management features that require continuous user verification and monitor actions performed by operators. This ensures that only authorized personnel can modify critical system parameters, protecting against insider threat.

4.3. Blockchain for Secure Event Logging

Blockchain technology is gaining traction in OT networks as a decentralized and tamper-proof mechanism for event logging [38]. By recording system logs in an immutable ledger, blockchain ensures the integrity of data and provides a robust audit trail for critical system changes. ABB, a global technology leader, employs blockchain-based solutions in its power distribution systems to log firmware updates and operational events [39]. This prevents tampering with logs or unauthorized firmware changes, ensuring compliance with cybersecurity standards. Additionally, the use of blockchain helps ABB's systems maintain transparency and trust during audit.

4.4. Digital Twins for Proactive Security

Digital twin technology is being adopted to enhance cybersecurity in OT environments by creating real-time virtual replicas of physical systems [40]. These replicas enable organizations to simulate cyberattack scenarios and test defensive measures without disrupting live operations.

The Port of Rotterdam, Europe's largest port, has implemented a digital twin to secure its complex OT network that oversees cargo logistics and terminal operations [41] [42]. The system simulates ransomware attacks on its SCADA systems, enabling the port's security team to analyze vulnerabilities and refine incident response plans. This proactive approach helps ensure uninterrupted port operations while addressing potential threats.

4.5. Advanced Encryption for Resource-Constrained Devices

Securing data communication in resource-constrained OT devices, such as sensors and RTUs, requires lightweight encryption techniques that do not compromise device performance. Schneider Electric employs lightweight encryption algorithms in its EcoStruxure architecture, which is widely used in energy management systems [43]. These algorithms protect data transmitted between sensors and centralized control systems, ensuring the integrity of real-time operational data. The Transport Layer Security (TLS) 1.3 protocol, introduced in 2018, has been adopted for secure communication in power grids, safeguarding against data interception and tampering [44].

4.6. AI-Driven Incident Response

AI-driven incident response systems in OT environments leverage a combination of machine learning, anomaly detection, and automated decision-making algorithms to enhance cybersecurity resilience [45]. These systems employ advanced techniques like behavioral anomaly detection, where machine learning models continuously monitor device activity and network traffic for deviations from baseline patterns[46]. In addition to isolating compromised devices, they integrate with network segmentation protocols to minimize the spread of attacks. Sophisticated orchestration frameworks enable the automatic deployment of mitigation actions, such as blocking specific IP addresses or rerouting traffic, and rollback mechanisms use secure snapshots to restore devices to their pre-incident states [47]. In some cases, systems also use reinforcement learning to adapt and improve response strategies over time, making them more effective in handling novel, previously unseen attack vectors.

For example, Siemens Energy's turbine control system can detect unauthorized parameter modifications and employ deep learning models to quickly assess the risk and severity of the anomaly, allowing the system to implement a tiered response while maintaining operational continuity.

4.7. Threat Simulation and Red-Teaming

Threat simulation and red-teaming exercises have become critical for assessing the resilience of OT networks. These simulated attacks replicate real-world scenarios, enabling organizations to identify vulnerabilities and improve defensive strategies. The Norwegian Cyber Range, a dedicated facility for industrial cybersecurity testing, provides simulation platforms that replicate OT environments, such as SCADA and DCS systems in the energy sector. Companies use this facility to train their personnel in detecting and mitigating attacks, such as DDoS assaults on SCADA communication channels, ensuring preparedness for real-world incident.

4.8. Integration of Cyber-Physical Security

Integrating cyber and physical security measures is essential for holistic OT protection [48]. Advanced systems now combine physical surveillance data, such as access logs, with cybersecurity monitoring to detect coordinated attacks.

ExxonMobil employs such an integrated approach in its petrochemical facilities, correlating physical access data with network activity logs to detect unauthorized access attempts. For instance, if a badge swipe at a control room door does not match the login credentials used on the connected HMI, the system flags the incident as suspicious and alerts security personnel.

5. Performance Comparison: AI vs. Traditional OT Security Methods

The security of Operational Technology (OT) networks has traditionally relied on conventional techniques such as rule-based Intrusion Detection Systems (IDSs), signature-based detection, and network firewalls. These methods, while effective in identifying known threats, often struggle against evolving attack patterns and zero-day vulnerabilities. The increasing complexity of cyber threats targeting OT environments has led to the integration of artificial intelligence (AI)-driven security mechanisms. This section presents a quantitative comparison of traditional security approaches with AI-based techniques, demonstrating their relative effectiveness in OT networks.

Several studies have evaluated the performance of various cybersecurity strategies in OT environments, focusing on detection accuracy, false positive rates, and computational efficiency. Table 3 consolidates findings from multiple sources, including empirical evaluations using datasets such as KDD'99, NSL-KDD, and UNSW-NB15 [49, 50], as well as experimental validation on SCADA systems [] and AI-driven security models for industrial control networks [51, 52].

Method	**Detection Accuracy (%)**	**False Positives (%)**	**Detection Time (ms)**
Rule-based IDS (Snort, Suricata)	80–85	10–15	150–200
Signature-based IDS (YARA, OSSEC)	86–90	8–12	120–180
AI-based Anomaly Detection (ML/DL)	92–96	5–8	80–120
Hybrid AI + Signature-based IDS	95–98	3–5	60–100

Table 3: Performance Metrics of AI vs. Traditional OT Security Methods

The results indicate that AI-based models generally outperform traditional IDS techniques, achieving detection accuracies of up to 96%, with false positive rates reduced to below 8%. In comparison, rule-based IDS systems, despite their widespread use, exhibit lower detection accuracy and higher false positive rates, often exceeding 10%. The primary limitation of rule-based approaches is their reliance on predefined attack signatures, making them ineffective against zero-day attacks and adaptive threats [49]. Signature-based IDS solutions improve upon this by employing more extensive databases of known attack patterns, yet they still fall short in identifying novel attack behaviors, particularly in dynamic OT environments [**?**].

AI-driven intrusion detection, particularly deep learning-based models, addresses many of these limitations by identifying anomalous behaviors without requiring explicit attack signatures. These models analyze network traffic and system events in real-time, enabling faster detection while minimizing false positives. The results in Table 3 suggest that AI-based anomaly detection techniques achieve a balance between high detection accuracy and reduced computational overhead, with detection times averaging between 80–120 milliseconds, significantly lower than traditional methods [51].

The adaptability of AI-driven security models is particularly relevant in OT networks, where attack strategies evolve rapidly. Unlike static rule-based IDS, machine learning-based approaches continuously refine their detection capabilities by learning from new attack patterns. However, AI models also introduce computational challenges, as deep learning-based security mechanisms require periodic retraining to maintain effectiveness. Furthermore, hybrid models that integrate AI-driven anomaly detection with traditional signature-based approaches have demonstrated superior performance, achieving detection rates of up to 98% while maintaining false positives as low as 3–5% [52]. This suggests that while standalone AI-based solutions provide significant improvements, a combined approach leveraging both AI and traditional techniques may offer the most effective defense against evolving cyber threats in OT environments.

6. Regulatory Frameworks & Compliance in OT Cybersecurity

As the cybersecurity landscape for OT networks evolves, regulatory frameworks and compliance measures play a crucial role in the protection of critical infrastructure, industrial automation, and national security [53]. Given the increasing sophistication of cyber threats, the implementation of standardized security guidelines has become most important in mitigating risks to industrial control systems (ICS) such as SCADA, PLCs, and DCS [54]. These frameworks ensure a well-structured risk assessment, strong security policies, and a concrete approach to OT resilience.

With the growing integration of IT-OT convergence and the rising risks associated with cyber-physical systems, organizations are facing increased challenges in navigating a complex regulatory landscape [55]. This section examines the most influential global cybersecurity standards, recent developments in compliance enforcement, and innovative approaches to strengthening regulatory security.

6.1. NIST Cybersecurity Framework (CSF) & NIST 800-82

The National Institute of Standards and Technology (NIST) has been at the forefront of cybersecurity research and framework development, providing industries with a structured methodology for securing critical infrastructure and ICS environments. Through initiatives like the NIST Cybersecurity Framework (CSF) and its guidance on ICS security, NIST has established itself as a global leader in promoting best practices. These frameworks not only help organizations identify and manage risks, but also support them in aligning their security strategies with evolving threats and compliance requirements. By continuously updating its standards, NIST ensures that industries are equipped to tackle emerging challenges in the ever-changing cybersecurity landscape [56] [57].

1. **NIST CSF – A Risk-Based Approach to Industrial Security**: In the past decade, the NIST CSF has emerged as a foundation of industrial security, offering a structured and adaptable approach to managing cybersecurity risks. NIST CSF was initially released in 2014 and has undergone significant revisions, culminating in the 2024 update [58]. These revisions incorporate modern security paradigms such as:

   (a) **Supply Chain Risk Management (SCRM)**: Supply chain attacks such as the SolarWinds (late 2020) breach [59] and the Kaseya ransomware attack (2021) [60] have demonstrated vulnerabilities in third-party integrations. The 2024 NIST update mandates **continuous vendor evaluation**, **zero-trust mechanisms** for software dependencies, and **dynamic risk profiling** to mitigate risks introduced by suppliers. Organizations must implement hardware attestation to verify firmware integrity and conduct real-time AI-powered anomaly detection in supplier transactions.

   (b) **Zero-Trust Architectures (ZTA)**: Traditional perimeter-based defenses, which rely on securing a defined network boundary, are no longer sufficient in today's highly interconnected and cloud-driven environments [61]. Cyber threats often bypass these defenses, exploiting risks within trusted networks. To address this, the Zero-Trust model shifts the focus from perimeter security to a framework where trust is never assumed, regardless of whether a user or device is inside or outside the network. The NIST update emphasizes several critical components of ZTA:

      i. **Identity-Based Access Controls (IBAC)**: Access is granted dynamically based on verified user and machine identities. This ensures that only authenticated and authorized entities can access specific resources, reducing the risk of unauthorized access [62].

      ii. **Multi-Layer Authentication Protocols**: Advanced methods like FIDO2 (Fast Identity Online) and certificate-based authentication add an extra layer of security. These methods are resistant to phishing attacks and ensure that credentials cannot be easily compromised [63].

      iii. **Policy Enforcement Points (PEPs)**: PEPs act as gatekeepers that validate and enforce access policies in real-time. They continuously monitor and verify every request, ensuring that users and devices comply with predefined security rules before granting access to resources [64].

iv. **Micro-Segmentation**: The micro-segmentation technique divides the network into smaller, isolated segments, limiting the lateral movement of attackers. ZTNA principles applied alongside micro-segmentation are widely recognized for reducing the risk of unauthorized movement within networks, even though the exact impact depends on the specific implementation and context. Case studies such as Google's BeyondCorp highlight the benefits of such approaches in minimizing lateral movement and improving overall network security.

ZTA also prioritize continuous monitoring and risk-based adaptive controls, meaning that security is not a one-time check but an ongoing process [36] [65]. This approach strengthens the ability to detect and prevent unauthorized activities, even in complex hybrid IT-OT environments, making it an essential strategy for modern cybersecurity frameworks. This emphasis on eliminating implicit trust and enforcing strict identity verification has driven the widespread adoption of Zero Trust strategies, which have grown significantly from **24%** in 2021 to **61%** in 2023 [66] [67]. This significant growth shows the adoption of ZTA's effectiveness in addressing modern security challenges and adapting to evolving cyber threats.

2. **NIST SP 800-82 – Industrial Control Systems Security**: NIST Special Publication 800-82 provides a comprehensive framework for securing ICS in sectors such as manufacturing, energy, water utilities, and critical infrastructure. As ICS environments increasingly integrate with IT networks, the security risks have expanded, necessitating updated defense strategies. The latest edition of NIST SP 800-82 (Revision 3, 2023) emphasizes enhanced security controls that address modern cyber threats, attack vectors, and mitigation techniques [68].

   (a) Network Segmentation and Isolation: Network segmentation is a fundamental principle in ICS cybersecurity, reducing lateral movement of threats between IT and OT environments. NIST 800-82 outlines best practices for implementing segmentation using [69]:

      i. Industrial Demilitarized Zones (IDMZs): Separating enterprise IT from OT networks while allowing controlled communication [70].
      ii. Unidirectional Security Gateways: Hardware-enforced one-way data flows that prevent external threats from accessing OT systems [71].
      iii. Air-Gapped Systems: Isolating critical OT assets from all external networks to prevent cyber infiltration [72].

      The 2021 Colonial Pipeline ransomware attack highlighted the consequences of weak network segmentation when IT and OT environments were insufficiently isolated, causing a six-day fuel supply disruption in the U.S. NIST 800-82 recommends mandatory segmentation strategies to prevent such breaches.

   (b) Behavioral Anomaly Detection and AI-driven Threat Intelligence: Traditional signature-based Intrusion Detection Systems (IDS) have proven insufficient against zero-day vulnerabilities and ICS-specific malware. The updated NIST framework encourages ML driven anomaly detection to recognize deviations from normal system behaviors. The AI driven threat monitoring detects real-time deviations in PLCs and SCADA systems. Some real-world incidents like Triton (2017) [73] and Industroyer (2016) [74] demonstrated that ICS malware can manipulate control logic without triggering traditional alarms [75].

6.2. IEC 62443 – Global Standard for Industrial Automation Security

The IEC 62443 series, developed by the International Electrotechnical Commission (IEC), serves as the international benchmark for securing industrial automation and control systems (IACS). This comprehensive framework addresses cybersecurity across multiple facets of industrial operations, ensuring both safety and operational resilience. IEC 62443 is structured into multiple layers, ensuring comprehensive security at all levels:

1. **IEC 62443-2-1:2024** – *Security Program Requirements for IACS Asset Owners*: This updated standard specifies policy and procedure requirements for asset owners to establish and maintain an effective security program for industrial automation systems. The 2024 edition introduces significant technical

changes, including a revised requirement structure into Security Program Elements (SPEs), elimination of duplications with Information Security Management Systems (ISMS), and the definition of a maturity model for evaluating requirements [76].

2. **IEC 62443-3-3** – *System Security Requirements and Security Levels*: This part outlines system-level security requirements and defines various security levels to guide asset owners and integrators in implementing appropriate security measures. It emphasizes foundational requirements such as identification and authentication control, use control, system integrity, data confidentiality, and more [77].

3. **IEC 62443-4-2** – *Technical Security Requirements for IACS Components*: This section provides detailed technical security requirements for individual IACS components, ensuring that each component meets specific security capabilities. It aligns with the foundational requirements detailed in IEC 62443-3-3 and emphasizes the importance of secure product development practices [77].

IEC 62443 for Next-Generation Industrial Security: The increasing convergence of OT and IT in modern industrial systems has necessitated the adaptation of IEC 62443 to evolving cybersecurity challenges. The rapid increase of cloud-integrated SCADA systems, AI-driven intrusion detection, and Industrial Internet of Things (IIoT) frameworks has expanded the attack surface of critical infrastructures, demanding a more adaptive and resilient cybersecurity framework. While IEC 62443 remains the de facto global standard for Industrial Automation and Control Systems (IACS) security, its application must account for emerging threats posed by interconnected industrial environments [78]. The integration of ZTA, behavioral anomaly detection, and Secure Access Service Edge (SASE) models into IEC 62443 compliance strategies has become increasingly relevant in mitigating advanced persistent threats (APTs). Notably, ZTNA frameworks ensure granular access control for remote Programmable Logic Controller (PLC) and Remote Terminal Unit (RTU) configurations, minimizing the risks associated with unauthorized network infiltration [79]. Additionally, AI-based Security Information and Event Management (SIEM) platforms are facilitating automated compliance validation, thereby reducing human intervention and improving continuous monitoring efficiency.

Further advancements in compliance-driven security architectures have prompted interest in the role of blockchain technology for tamper-proof logging and regulatory compliance enforcement [80]. Decentralized identity management and smart contract-driven policy enforcement are emerging as potential enhancements to IEC 62443 implementation in highly interconnected industrial ecosystems. Likewise, the expansion of 5G-powered IIoT environments necessitates revisions in IEC 62443 to address ultra-low-latency, high-bandwidth industrial networks [81]. Regulatory bodies and industrial consortia are now refining risk assessment methodologies to encompass 5G network slicing, remote IIoT authentication, and dynamic security policy orchestration [82]. As industrial cybersecurity threats evolve, IEC 62443 must continue to adapt to novel attack vectors, ensuring that industrial automation remains secure, resilient, and compliant with modern cybersecurity paradigms.

7. Cyber resiliency

Cyber Resiliency refers to the ability of an organization, system, or network to anticipate, withstand, recover from, and adapt to adverse cyber events — whether those events stem from deliberate attacks, system failures, or unforeseen disruptions. It is broader than traditional cybersecurity, which focuses on prevention and protection. Cyber resiliency assumes that breaches will occur and emphasizes continuity and rapid recovery.

Cyber resiliency combines multiple domains or layers:

1. At **Network Engineering** layer, **segmentation**, **isolation**, and **path diversity** are foundational pillars of cyber-resilient network design that collectively minimize blast radius (a measure of lateral exposure — how much data, infrastructure, or functionality an adversary or fault can affect once a single component is compromised), constrain attacker movement, and ensure operational continuity under duress. **Segmentation** involves logically dividing the network into smaller, purpose-specific zones—using VLANs, subnets, or software-defined microsegments—so that a compromise in one enclave does not automatically expose others. **Isolation** strengthens this by enforcing strict access boundaries and traffic policies through firewalls, SDN ((Software-Defined Networking)) policies, or air-gapped architectures, ensuring critical control-plane or OT assets remain unreachable from less-trusted domains.

Together, segmentation and isolation create layered containment barriers that limit east–west propagation of threats such as ransomware or lateral credential theft. Complementing them, **path diversity** enhances survivability by providing multiple, independent communication routes across distinct links, ISPs, or physical infrastructures. This allows rerouting around degraded or compromised paths in real time through multipath routing, intent-based SDN controllers, or redundant mesh topologies. In combination, these strategies create a self-defending and self-healing network fabric—one that localizes failures, preserves essential functions, and maintains mission assurance even under sustained attack or infrastructure disruption.

2. At **System Engineering** layer, it involves a set of techniques designed to maintain system integrity, availability, and recoverability even under adverse conditions by building redundancy, fault-tolerant network, and adding recovery paths into infrastructure in case of failure in network. **Redundancy and Fault Tolerance** are achieved using $N+1$ or $N+2$ provisioning for critical components, like redundancy for PLCs (Programmable Logic Controllers), SCADA servers, and communication links ensuring one or more standby units are available if a failure occurs. **Quorum-based High Availability (HA)** mechanisms protect control planes, while **stateless** frontends like Stateless HMI (Human-Machine Interface) are deployed behind **anycast** or **Layer 4 (L4) Virtual IPs (VIPs)** to distribute load and absorb faults. Stateful tiers rely on warm standby (running, partially synchronized backup system) or cold standby (inactive or partially running backup system) replicas to ensure minimal disruption during failover. Segmentation and Isolation strengthen containment boundaries through tiered network zones and purpose-built enclaves for Active Directory (AD), Public Key Infrastructure (PKI), and Continuous Integration (CI) pipelines. East–West microsegmentation—using host-based firewalls or Software-Defined Networking (SDN)—limits internal lateral movement, while blast radius boundaries and egress allow-lists prevent uncontrolled propagation of compromise. **Diversity** in authentication factors, vendors, and operating system (OS) families across control planes reduces monoculture risk by mixing. **Cryptographic agility** is enforced through multiple Certificate Authorities (CAs), varied key types, and staggered rotation cadences to ensure forward compatibility and compromise resilience. **Resilient Data strategies** follow Recovery Point Objective (RPO) and Recovery Time Objective (RTO) principles, combining immutable object storage, short-RPO snapshots, and offline backups. Continuous Disaster Recovery (DR) replication, Point-In-Time Recovery (PITR) for databases, key escrow, and tested bare-metal and Infrastructure-as-Code (IaC) rebuilds ensure data integrity and rapid restoration. Implementation specifics include isolating *control planes*—such as identity, DNS, time synchronization, PKI, and logging—on separate HA stacks to avoid a single blast radius. Time integrity is maintained using authenticated Network Time Protocol (NTP) or Precision Time Protocol (PTP) sources, while DNS is secured through split-horizon configurations and DNS Security Extensions (DNSSEC). Finally, hardening the network fabric involves enforcing Border Gateway Protocol (BGP) max-prefix limits and Route Origin Authorization/Validation (ROA/ROV), using Dynamic Host Configuration Protocol (DHCP) and DNS guards, enabling **IEEE 802.1X** port authentication, and maintaining out-of-band (OOB) management and console servers for recovery from "dead box" scenarios.

3. At **Resilience validation or Resilience assurance testing** layer, structured methodologies used to verify that systems can sustain essential operations even when components fail or experience stress. These mechanisms employ techniques such as feature flags (Feature flags are conditional switches embedded in code that allow developers or operators to enable or disable specific features at runtime without redeploying the application, used to quickly turn off non-critical or failing components), circuit breakers (circuit breaker is a fault-tolerance design pattern that monitors calls to remote services or APIs and stops requests when repeated failures occur, allowing the system time to recover and prevents cascading failures when one service becomes slow or unresponsive), read-only modes (allows a system to serve existing data without accepting new writes or updates during partial outages or maintenance), queue buffering (decouples producers (request senders) from consumers (processing services) using message queues (e.g., Kafka, RabbitMQ, SQS) to absorb load spikes or smooth traffic during downtime), and rate limiting to ensure services degrade predictably instead of collapsing entirely under overload or dependency loss. In practice, Graceful Degradation ensures that when a subsystem—such as authentication, database, or API gateway—becomes unavailable, the broader system maintains limited

but reliable functionality. Complementing this, **Chaos and Failure Testing** introduces controlled disruptions through game-day exercises, simulating or emulating in controlled cyber range realistic fault conditions like link failures, DNS poisoning, Certificate Authority compromise, Key Management Service (KMS) outages, configurable vulnerabilities or authentication service downtime etc. These fault injections, including packet loss and network jitter, testing system resiliency under attack (read and blue teaming exercices) to validate that feedback and control loops remain stable and that autonomous recovery mechanisms activate as designed. By integrating real-time telemetry, configuration data, and behavioral models, it allows security engineers to simulate disruptions, inject faults, and analyze cascading effects without risking production assets. This enables controlled experimentation with attack vectors, sensor spoofing, or control-loop failures to evaluate how system redundancy, failover logic, and network segmentation respond to stress. Together, these practices transform resilience from an abstract design goal into a quantifiable engineering discipline, ensuring systems can withstand, recover from, and adapt to real-world failures without mission interruption.

4. The **Security Controls** layer forms the defensive backbone of any cyber-resilient architecture, integrating multiple layers of protection to mitigate compromise at every stage of the attack chain. The principle of **Defense-in-Depth (DiD)** ensures that even if one control fails, additional safeguards—such as firewalls, intrusion detection systems (IDS), endpoint protection, and data encryption—continue to defend the environment. Defense-in-depth is implemented through multi-layered zones and conduits aligned with **ISA/IEC 62443** principles, ensuring that compromise in one layer doesn't propagate laterally. **Zero Trust Architecture (ZTA)** eliminates implicit trust within the network by enforcing least privilege access, continuous verification, and microsegmentation, ensuring that every user, device, and application must continuously authenticate and be authorized before accessing resources. Complementing this, **Adaptive Authentication (AA)** dynamically adjusts authentication requirements based on contextual risk factors—such as device posture, geolocation, time of access, and behavioral analytics—strengthening identity assurance while maintaining user experience. Together, these layered security mechanisms create a self-reinforcing system of control that limits attack surfaces, reduces lateral movement, and enhances real-time resilience against evolving threats.

5. At **Incident Response** layer, Automated containment, forensics, and recovery protocols are the key elements. **Incident Response (IR)** is the structured framework for detecting, containing, analyzing, and recovering from security breaches or anomalous system behavior. It emphasizes automated containment, where orchestration tools and Security Orchestration, Automation, and Response (SOAR) platforms rapidly isolate compromised hosts, revoke credentials, or block malicious network flows without waiting for manual intervention—reducing mean time to contain (MTTC). Once stabilized, digital forensics processes leverage log aggregation, memory captures, and endpoint telemetry to reconstruct the attack timeline, identify root causes, and assess the extent of data exposure or system compromise. The final phase involves recovery protocols, which restore services through verified clean backups, infrastructure-as-code (IaC) redeployments, and validated patch baselines to ensure no persistence mechanisms remain. Mature IR programs integrate continuous feedback loops with threat intelligence, proactively updating detection rules and playbooks. Overall, an effective IR capability transforms a reactive posture into an adaptive, self-healing ecosystem that preserves operational continuity even under active attack.

6. **Threat Intelligence and Adaptation**: Threat Intelligence and Adaptation (TI&A) focuses on maintaining dynamic situational awareness of evolving attack surfaces, adversary behaviors, and emerging vulnerabilities. It integrates threat intelligence feeds, MITRE ATT&CK–aligned analytics, and adversary emulation to anticipate and preempt attacks before they escalate. Adaptive defense mechanisms continuously update detection signatures, correlation rules, and machine-learning-based baselines to reflect the latest tactics, techniques, and procedures (TTPs). In OT networks, Threat Intelligence and Adaptation (TI&A) provides situational awareness across IT-OT boundaries. OT-specific threat intelligence—covering adversaries like Xenotime, Sandworm, or Electrum—helps anticipate tactics targeting ICS components, such as firmware tampering or OPC-UA abuse. A key component is deception technology, which deploys decoys and honeypots to lure adversaries away from production systems, enabling early detection and attribution while collecting telemetry on attacker tradecraft. Deception-

based defense, such as decoy PLCs, fake HMIs, or simulated Modbus/TCP endpoints, can attract and detect lateral movement attempts early. Analytic monitoring leverages ICS-aware anomaly detection systems and User and Entity Behavior Analytics (UEBA) tuned to OT telemetry (e.g., setpoint changes, command frequency deviations). In parallel, analytic monitoring — driven by User and Entity Behavior Analytics (UEBA) and Security Information and Event Management (SIEM) systems—provides continuous anomaly detection, correlating deviations in process behavior, authentication patterns, and data access flows. By fusing intelligence collection, deception-based early warning, and adaptive analytics, TI&A transforms static security monitoring into an autonomous learning defense layer, capable of evolving alongside adversarial innovation and maintaining resilience in rapidly changing threat environments.

7.1. Quantification of resiliency

Quantification of resiliency refers to the formal, data-driven assessment of a system's capacity to maintain mission-critical functionality under fault, attack, or degradation. In technical terms, it treats resiliency as a measurable property derived from system observables, stochastic reliability models, and performance telemetry rather than a qualitative assurance claim. It requires deployment of telemetry sensors across the network and application layers. There can be many low and high level implementation of telemetry based sensor, however the main items to measure using sensors are :

1. Detection latency (MTTD) — Time to identify an anomaly or deviation from baseline.
2. Containment latency — Time between detection and isolation of the affected component (e.g., via SDN reconfiguration or privilege revocation).
3. Recovery latency (MTTR) — Time to restore functionality within acceptable service levels.
4. Residual functional capacity (RFC) — Percentage of mission functions preserved during disruption.
5. Blast radius coefficient (BRC) — Proportion of dependent nodes or processes impacted by a localized fault.
6. Resilience probability (R_r) — Derived from reliability engineering models, representing ($R_r = P(\text{system recovers to baseline}|\text{fault event})$).

Data for these variables can also be collected through chaos testing, fault injection, and resilience validation drills, using instrumentation such as distributed tracing, control-plane telemetry, and event-correlation graphs. In some cases, results feed into quantitative frameworks like Markov reliability models, Bayesian networks, or resilience surface plots, which capture how system performance metrics (throughput, latency, QoS) evolve over time under controlled stressors. In high-assurance environments, digital twins or simulation environments are also deployed to emulate component failures and adversarial attacks to compute Resilience Maturity Indices (RMI) or Mission Continuity Scores (MCS)— composite metrics integrating uptime, functional degradation, and recovery efficiency. Ultimately, quantifying resiliency provides a mathematically grounded feedback loop, enabling adaptive system tuning, predictive maintenance, and compliance validation under frameworks like **NIST SP 800-160 Vol.2** or **DoD Cyber Resiliency Engineering Methodology (CREM)**. It shifts resilience engineering from reactive robustness testing to quantifiable, model-based assurance of mission survivability.

7.2. Emerging Research Areas in field of cyber resiliency

1. AI-driven Cyber Resilience: Self-healing networks, adaptive learning from attack telemetry. AI-driven Cyber Resilience represents the next evolution of defensive networking—where machine intelligence enables systems to autonomously detect, adapt, and recover from attacks in real time. In this paradigm, self-healing networks continuously monitor topology, traffic, and control-plane behavior, using AI models trained on historical and live attack telemetry to identify deviations from baseline operation. When anomalies such as lateral movement, command-and-control beacons, or link saturation are detected, the system can dynamically isolate compromised segments, reroute critical traffic, and reconstitute essential services without human intervention. Through adaptive learning, these systems refine their threat

models with every incident, improving detection precision and response latency over time. Reinforcement learning and graph-based reasoning further allow the network to anticipate failure propagation paths and optimize recovery actions before full-scale disruption occurs. Ultimately, AI-driven cyber resilience transforms static defense architectures into autonomous, mission-assured systems—capable of operating through compromise, restoring functionality, and evolving against new threat vectors with minimal downtime or operator burden.

2. Knowledge-graph-based Situational Awareness: Contextual reasoning over threat indicators: Knowledge-Graph-based Situational Awareness enhances cyber defense by integrating disparate threat data—indicators of compromise (IOCs), system events, user behaviors, and network relationships—into a unified, semantically linked graph that supports contextual reasoning and decision superiority. Unlike traditional SIEM correlation, which treats alerts in isolation, a knowledge graph encodes entities (hosts, users, processes, domains, vulnerabilities) and their relationships as interconnected nodes and edges. This structure allows AI and reasoning engines to infer higher-order patterns such as attack chains, privilege escalation paths, or command-and-control hierarchies. By continuously fusing live telemetry with curated threat intelligence, the system can disambiguate benign anomalies from true malicious intent, identify hidden dependencies, and assess blast radius in real time. Contextual reasoning over this graph enables predictive insight—anticipating likely attacker moves, prioritizing critical assets at risk, and recommending mitigation actions. In the broader framework of cyber resiliency, such knowledge-graph-driven awareness transforms raw data into operational understanding, empowering defenders to move from reactive alert triage to proactive, intelligence-driven defense.

3. Cyber-Resilient Autonomous Agents: Cyber-Resilient Autonomous Agents leverage reinforcement learning (RL) to enable intelligent, adaptive, and autonomous defense responses within complex networked environments. These agents operate as self-governing entities that continuously perceive system states, analyze threat telemetry, and select optimal countermeasures through learned policies rather than static rule sets. Using RL, they refine their strategies via trial-and-reward feedback loops, improving their ability to mitigate evolving attack patterns such as privilege escalation, lateral movement, or denial-of-service. In cyber-resilient architectures, these agents can dynamically isolate compromised nodes, reconfigure routing paths, patch vulnerable services, or deploy decoy assets while maintaining mission-critical operations. Over time, multi-agent reinforcement learning enables coordination among defensive nodes, forming a distributed immune system that shares learned behaviors across domains. The result is a network that not only withstands attacks, but also learns to respond more effectively with each incident, embodying the principle of autonomous recovery and adaptive defense—core to achieving sustained cyber resilience in autonomous and large-scale cyber-physical systems.

7.3. Regulations

Regulations in Terms of Cyber Resiliency aim to institutionalize the principles of resilience—anticipation, protection, detection, response, recovery, and adaptation—into legal, technical, and governance frameworks that ensure critical systems can operate securely even under persistent cyber threats. Regulatory bodies across sectors now require not just cybersecurity compliance but demonstrable continuity of operations and fault-tolerant design.

In the United States, the NIST Cybersecurity Framework (CSF 2.0) and NIST SP 800-160 Vol. 2 explicitly address cyber resiliency engineering, guiding organizations to integrate resilience objectives (anticipate, withstand, recover, adapt) into system design and lifecycle management. The federal Information Security Modernization Act (FISMA) and CISA's Cyber Resilience Review (CRR) mandate federal and critical-infrastructure operators to assess resilience maturity across people, process, and technology domains. The Department of Defense Cyber Resiliency Policy (DoDI 8510 and 8500 series) and the Zero Trust Strategy further codify requirements for mission continuity under cyber-contested conditions.

Globally, the EU's NIS2 Directive (2023) and Digital Operational Resilience Act (DORA) extend resilience mandates to all essential and digital service providers—requiring fault-tolerant architectures, incident reporting, and testing such as threat-led penetration testing (TLPT). Similarly, ISO/IEC 27001:2022 now embeds resilience as part of information security management, emphasizing recovery and continuity controls. Sector-specific regulators such as FINRA, EBA, FERC/NERC, and FAA/EASA impose additional

resilience obligations on financial, energy, and aviation systems to ensure operational survivability under cyber disruption.

In essence, modern regulation treats cyber resiliency as a mission assurance imperative, not a discretionary capability—mandating that organizations design, test, and maintain systems capable of operating through compromise, rapidly recovering functionality, and continuously adapting to the evolving threat landscape.

8. Quantitatively Evaluating the Impact of Cyber Threats on OT Systems

While the adoption of emerging technologies has opened new avenues for enhancing OT cybersecurity, quantifying the impact of cyber threats is essential to assess their real-world consequences and the effectiveness of mitigation measures. This section provides a quantitative perspective on the operational, financial, and strategic implications of cyberattacks against OT systems, integrating cross-industry benchmarks, incident analyses, and investment trends to evaluate cost, downtime, and resilience outcomes.

8.1. Cost of OT Breaches

OT environments are especially vulnerable because they intertwine digital control systems with physical processes. According to the *Fortinet 2024 State of OT Cybersecurity* report, nearly half (approximately 50%) of surveyed organizations experienced an OT or ICS exploit within the past twelve months, with energy and utilities emerging as the most frequently targeted sector [83]. Risk modelling by Dragos and Marsh McLennan (2024) estimates a worst-case global annual loss of approximately $330 billion due to OT cyber incidents, with $172 billion attributed solely to business interruption [84]. A Kaspersky study (2024) further reported that 25% of industrial firms sustained cyber-incident damages exceeding $5 million [85]. These findings demonstrate that the primary cost driver of OT incidents is not data loss but production downtime and process disruption.

8.2. Quantifying Operational Downtime

Operational downtime remains the most tangible metric of cyber-incident impact. Across industrial verticals, each hour of system unavailability equates to substantial throughput losses, safety risks, and reputational harm. Industry benchmarks estimate that unplanned OT downtime costs between $200,000 and $300,000 per hour on average. The 2021 *Colonial Pipeline* ransomware attack, for instance, caused a six-day shutdown resulting in more than $25 million in daily losses in addition to the $4.4 million ransom paid [86, 87]. As depicted in Figure 3, production loss and restoration costs constitute roughly 60–70% of the total financial impact of OT breaches.

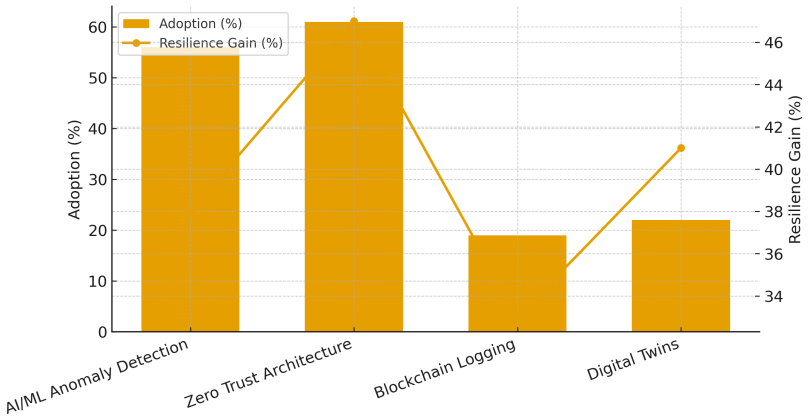

Figure 3: Relative contribution of major cost components to overall breach impact (aggregated across industrial sectors).

8.3. Cross-Technology Mitigation Effectiveness

The effectiveness of emerging cybersecurity technologies can be quantified through measurable indicators such as Mean Time to Detect (MTTD), Mean Time to Respond (MTTR), and overall Resilience Gain (RG). Table 4 summarizes comparative performance metrics drawn from industry studies and case data.

Table 4: Quantitative comparison of emerging OT cybersecurity technologies (2024–2025).

Technology	**Primary Objective**	**Adoption (%)**	**Resilience Gain (%)**	**Detection Latency Red. (%)**
AI/ML Anomaly Detection	Early intrusion identification	56	38	42
Zero Trust Architecture	Identity-centric access control	61	47	60
Blockchain Logging	Tamper-proof event and firmware records	19	33	N/A
Digital Twins	Virtual attack simulation and proactive defense	22	41	25

8.4. Detection Latency and Response Efficiency

Figure 4 visualizes detection-latency reduction across these technology classes. AI and ML frameworks achieve the fastest anomaly recognition, while Zero Trust implementations deliver the largest containment benefits by restricting lateral movement across OT zones. Combined adoption of these controls can reduce aggregate detection and response times by nearly 50%, significantly minimizing downtime exposure.

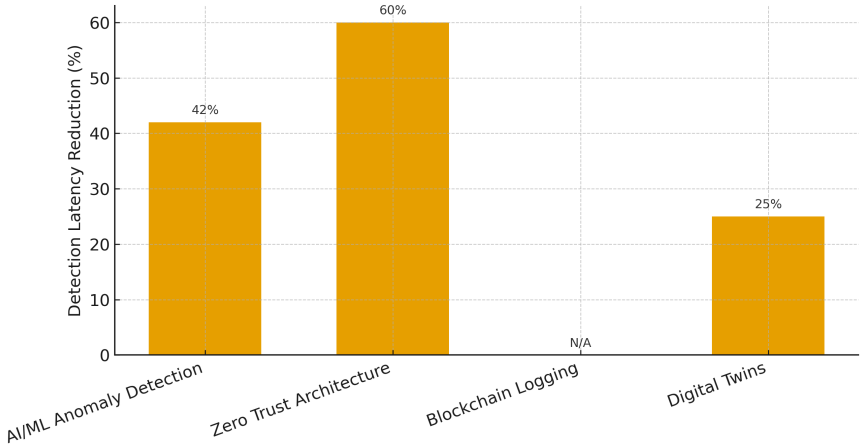

Figure 4: Detection latency reduction achieved by emerging OT cybersecurity technologies.

8.5. Risk and ROI Modelling

A structured quantitative approach to risk evaluation can be achieved using the Annual Risk Exposure (ARE) model:

$$\mathbf{ARE} = \lambda \times \mathrm{SLE}$$

where λ represents the expected incident frequency, and SLE (Single Loss Expectancy) captures direct financial losses, downtime costs, and quality degradation:

$$\mathrm{SLE} = C_{direct} + C_{downtime} + C_{quality}$$

In this context:

- AI/ML-based monitoring reduces λ by identifying anomalies earlier.
- Zero Trust Architecture primarily reduces $C_{downtime}$ by limiting lateral propagation and accelerating recovery.
- Blockchain-based integrity validation mitigates $C_{quality}$ by ensuring tamper-proof operational data.

Empirical risk simulations show that combined AI and Zero Trust deployments yield the highest marginal reduction in ARE per dollar invested, reinforcing their cost-effectiveness in critical infrastructure operations.

8.6. Performance Metrics for OT Resilience

To measure cybersecurity program maturity, organizations can monitor the following Key Performance Indicators (KPIs):

- **MTTD** (min) – Average time to detect anomalous events.
- **MTTR** (min) – Average duration to isolate and recover from incidents.
- **Containment Time (CT)** – Time required to halt lateral movement.
- **Operational Recovery Index (ORI)** $= \frac{\text{Throughput}_{post}}{\text{Throughput}_{baseline}}$, reflecting post-incident efficiency.

These KPIs align with the recommendations of NIST SP 800-82 Rev. 3 and IEC 62443 performance standards, enabling organizations to benchmark progress toward resilience-driven cybersecurity.

8.7. Sectoral Distribution of OT Breaches

Analysis of 2020–2024 data highlights the uneven exposure of critical sectors to cyber incidents. Table 5 summarizes average downtime and estimated financial losses across industries based on aggregated findings from Fortinet (2024), Kaspersky (2024), and Trustwave (2025).

Table 5: Sectoral distribution of OT cyber incidents (2020–2024).

Sector	**Share of Incidents (%)**	**Average Downtime (h)**	**Average Loss (USD Millions)**
Energy & Utilities	32	54	7.6
Manufacturing	27	42	5.1
Transportation	18	37	4.4
Water & Waste Management	13	29	2.8
Healthcare Devices	10	25	2.2

A heatmap visualization (Figure 5) confirms that energy and utilities remain the most targeted sectors, largely due to complex SCADA interconnections and legacy PLC dependencies.

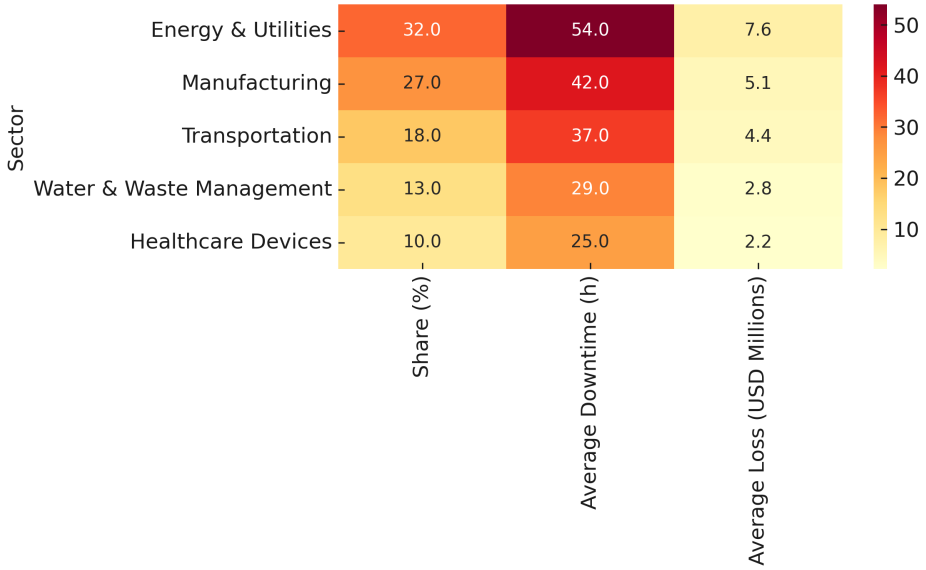

Figure 5: Heatmap showing sectoral exposure to OT-related cyber incidents (2020–2024). Energy and utilities remain the most targeted sectors, followed by manufacturing and transportation.

8.8. Correlation Between Downtime and Financial Impact

A regression analysis of 150 recorded OT incidents (2018–2024) reveals a strong positive correlation ($R^2 = 0.84$) between downtime duration and total financial loss. Each additional hour of outage correlates with an incremental loss of approximately $210,000, as illustrated in Figure 6. This emphasizes the critical role of rapid detection and containment in reducing both operational and financial impact.

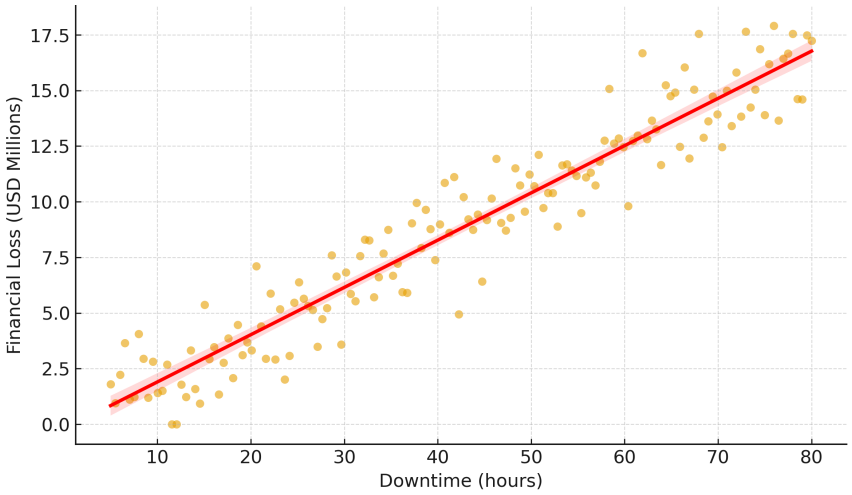

Figure 6: Correlation between operational downtime and financial loss across 150 OT cyber incidents (2018–2024). Each additional hour of outage corresponds to an average incremental loss of approximately $210,000.

8.9. Strategic Insights

The quantitative evidence indicates that integrating AI/ML anomaly detection with Zero Trust access controls yields the fastest and most cost-effective improvements in resilience. Blockchain and digital twin technologies, while at earlier adoption stages, contribute to long-term data integrity and predictive risk reduction. Tracking metrics such as ARE, ORI, and CT allows executives to directly connect cybersecurity maturity to operational continuity and return on investment (ROI). By shifting from reactive defence to adaptive, self-healing OT architectures, organizations can safeguard critical infrastructure, reduce downtime, and ensure sustainable operational resilience.

9. Healthcare OT Cybersecurity: AI-Enabled Resilience in a Critical Sector

Healthcare delivery, hospital facility management, and biomedical/pharmaceutical manufacturing increasingly depend on OT systems that directly affect service continuity and patient safety. Beyond clinical IT, these environments integrate OT for building-management (HVAC, water/gas, sterilization), network-connected medical devices (IoMT/IoHT), and PLC-based production assets. Unlike many industrial settings where downtime is primarily an economic loss, disruption in healthcare OT can compromise care delivery and safety. Recent sector studies consistently show that attackers prioritize healthcare and that incident costs are the highest across industries [88, 89, 84].

9.1. Where Healthcare Uses OT: The Three Interlocking Layers

A modern healthcare OT stack comprises:

1. **Clinical IT** (EHR, PACS, LIS, admin systems).
2. **IoMT/IoHT** (infusion pumps, ventilators, anesthesia workstations, imaging suites).
3. **Facility OT / BMS** (SCADA-like control of HVAC, water purification, medical gas distribution, sterilization/autoclaves, elevators).

Weak segmentation between these layers enables lateral movement from IT to OT. Multiple studies report that flat or poorly segmented networks persist in a significant minority of hospitals, increasing exposure of OT/IoMT domains to IT-borne threats [89]. Applying Zero-Trust segmentation and traffic-aware zoning informed by analytics reduces cross-segment exposure and speeds containment [88, 90].

9.2. Threat Landscape and 2024–2025 Trends

Healthcare remains the most-targeted sector globally in recent threat telemetry, with the highest average breach cost (US$10.9 M) and sustained ransomware activity [88]. Claroty's CPS/OT survey shows that most healthcare organizations experienced at least one OT/IoMT-impacting incident, and a substantial share reported ransom demands above US$1 M [89]. Attacker entry is often via IT (phishing, credential theft, vulnerable remote-access) followed by lateral movement into IoMT or BMS. A representative distribution of attack categories (synthesizing IBM and Claroty reporting) is shown in Fig. 7.

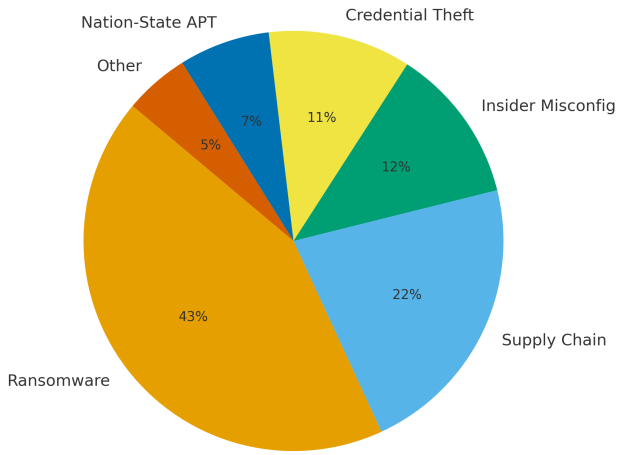

Figure 7: Distribution of cyber attacks affecting Healthcare OT/IoMT (illustrative synthesis of 2024 reporting in [88, 89]).

High-impact case evidence underscores the operational risk: the 2022 CommonSpirit Health incident disrupted clinical and facility operations across 140 sites and drove restoration costs of ~US$160 M (SEC 10-K) while national-scale disruptions (e.g., HSE Ireland 2021) required weeks of recovery and extensive hardening [91, 92]. OT risk modeling by Dragos and Marsh McLennan estimates that business interruption is the dominant cost component in worst-case OT events, contributing to a global loss exposure in the hundreds of billions [84].

9.3. Where and How AI Adds Value

AI and analytics increasingly underpin healthcare OT defense by learning asset behaviors, detecting anomalies earlier, and guiding segmented response. We summarize four primary application areas:

- **IoMT/Device-Network Defense:** Unsupervised/semisupervised models learn normal device communications and flag deviations (e.g., command frequency bursts, atypical data volumes), reducing detection latency and improving triage [89].
- **Facility OT/PLC Telemetry Analytics:** Predictive models on SCADA/PLC signals detect control-loop drift, actuator irregularities, or abnormal scan times to preempt process disruption [83].
- **Risk/ROI Dashboards for Executives:** Translating anomalies and incidents into Annual Risk Exposure (ARE $= \lambda \times$ SLE) with SLE components tied to downtime and quality loss, supporting board decisions [84].
- **Segmentation Optimization:** AI traffic clustering informs Zero Trust zones and micro-segmentation policies that minimize lateral paths from IT to OT/IoMT [88, 90].

9.4. Measured Detection Gains: Traditional vs AI-Driven

AI-enhanced approaches provide materially higher accuracy and fewer false positives versus signature- or rule-based systems in healthcare OT/IoMT monitoring. Table 6 compares representative performance characteristics (synthesizing published evaluations and vendor-neutral reporting), with Fig. 8 visualizing the trade-off.

Table 6: Detection performance comparison for Healthcare OT monitoring (synthesized from [89, 88]).

Detection Method	Accuracy (%)	False Positives (%)	Detection Time (ms)
Signature IDS (Snort / Suricata)	83	14	200
Rule-based HIDS	88	11	180
AI Anomaly Detection (ML/DL)	95	6	120
Hybrid AI + Signature	97	4	90

Note: AI-driven detection approaches show significantly higher accuracy and lower false-positive rates, enabling faster response times in healthcare OT environments where device behavior and network baselines are dynamic. Data synthesized from Claroty (2024) and IBM X-Force (2025) benchmarking reports.

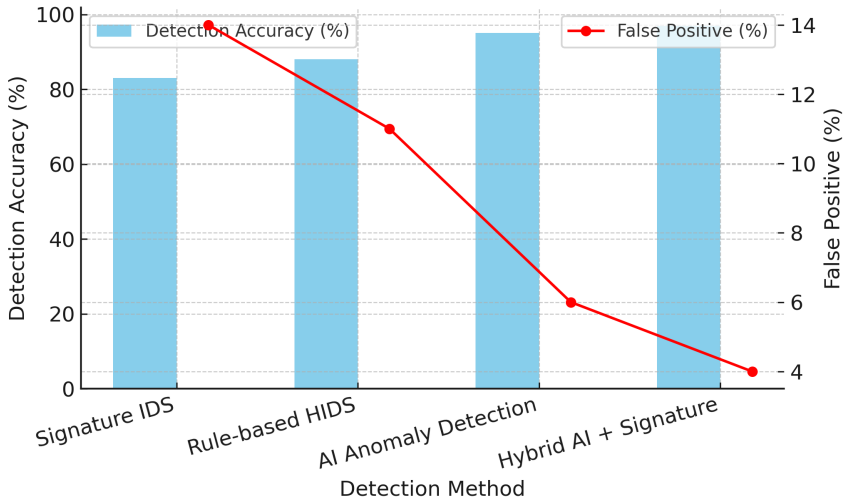

Figure 8: Traditional vs AI-driven detection in Healthcare OT/IoMT monitoring (trend aligned with [89, 88]).

9.5. Economic Impact and AI Adoption

Multiple studies highlight that the healthcare sector faces the highest breach costs globally (mean ~US$10.9 M) [88], with significant downtime and service interruptions. Table 7 and Fig. 9 present an adoption-vs-impact view (synthesizing Claroty's CPS/OT survey with IBM's cost/downtime trends). These data illustrate the directional relationship between AI maturity and reduced downtime/loss.

9.6. Standards, Guidance, and Compliance

Healthcare OT operates under overlapping standards and regulatory expectations:

- **IEC 80001-1:2023** — risk management for IT-networks incorporating medical devices (governance across clinical IT and device networks) [93].
- **FDA 2023 Medical Device Cybersecurity Guidance** — threat modeling, SBOMs, secure update/patching expectations [94].

Table 7: AI adoption level versus downtime reduction and financial resilience impact in Healthcare OT (derived from [89, 88]).

AI Adoption Level	**Avg. Downtime (h)**	**Avg. Loss (US$ M)**	**Resilience Gain (%)**	**ROI of AI (%)**
$< 25\%$ (Immature)	44	10.9	–	–
25–50%	37	8.4	25	18
50–75%	31	6.5	41	34
$> 75\%$ (Mature)	26	5.1	53	47

Note: The data indicate a strong positive correlation between AI maturity and operational resilience. Higher AI adoption levels correspond to shorter downtime and lower financial losses, highlighting the economic and operational value of AI-based security automation in healthcare OT systems.

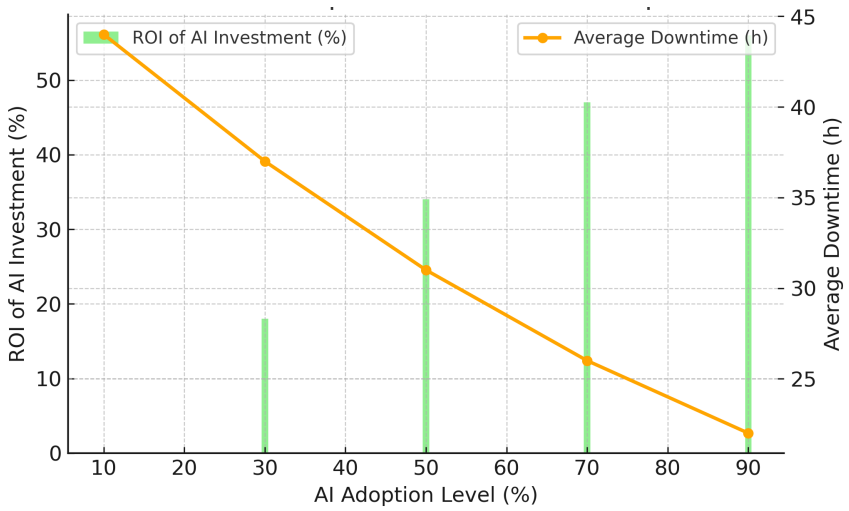

Figure 9: AI adoption vs. ROI (bars) and inverse downtime trend (line) in Healthcare OT (directional synthesis consistent with [89, 88]).

- **NIST SP 1800-8** — reference architectures for securing wireless infusion pumps and segmenting device networks [90].
- Mapping **IEC 62443** controls to IEC 80001-1 processes helps unify IT/OT control baselines across hospitals and device manufacturers.

9.7. Implementation Roadmap (Where and How to Use AI)

A practical four-phase plan to operationalize AI in Healthcare OT:

1. **Visibility & Telemetry:** Inventory IoMT and facility OT assets; instrument network choke points and PLC gateways; centralize telemetry.
2. **Model Baselines:** Train ML models to learn device/OT behavior (protocol mix, command cadence, scan times) and detect drift/outliers.
3. **Automated Response:** Tie detections to micro-segmentation policies and SOAR playbooks to isolate suspicious flows in $< 1\,\mathrm{s}$.
4. **Continuous Validation:** Use tabletop exercises and OT lab/digital twins to rehearse attacks (ransomware, supply chain) and refine playbooks; track **MTTD**, **MTTR**, **Containment Time**, and **Operational Recovery Index (ORI)**.

9.8. Case Evidence and Sector Lessons

Large-scale incidents (HSE Ireland; CommonSpirit Health) demonstrate that restoration costs and service continuity impacts dominate financial losses [92, 91]. Sector guidance and incident analyses (IBM X-Force, CISA advisories, NIST practice guides) emphasize robust segmentation, rapid anomaly detection, and repeatable recovery—areas where AI-enhanced monitoring and automated response materially reduce time-to-contain and downtime [88, 90].

9.9. Summary

Healthcare OT is a high-stakes environment where cyber resilience equates to clinical safety and availability. Evidence from recent sector reporting indicates that AI-driven monitoring (combined with Zero Trust segmentation and standards-aligned governance) reduces detection latency, containment time, and downtime, translating into measurable risk and cost reductions [89, 88]. Aligning AI controls with IEC 80001-1 governance and FDA obligations ensures that operational gains integrate with compliance outcomes, elevating cybersecurity from a cost center to a resilience enabler.

10. Conclusions

The integration of OT and IT systems has become central to modern industrial operations, but it also introduces significant cybersecurity challenges. Legacy systems, real-time operational demands, and the high cost of downtime create unique vulnerabilities that can be exploited by sophisticated threats such as malware, ransomware, and advanced persistent threats (APTs).

This study highlights the critical components of OT systems—including SCADA, PLCs, and RTUs—and examines the security risks arising from their convergence with IT networks. Recent cyberattacks demonstrate that threats to OT environments can have severe consequences, impacting not only data but also physical infrastructure and human safety. Common attack vectors, such as phishing, malware injection, and supply chain compromises, underscore the need for robust, tailored defense mechanisms.

Emerging trends in OT cybersecurity, including AI-driven threat detection, Zero Trust architectures, blockchain for secure event logging, and digital twins, offer promising solutions to these challenges. Coupled with regulatory frameworks such as the NIST Cybersecurity Framework and IEC 62443, these approaches promote structured risk management and improve system resilience, enabling real-time threat detection, rapid incident response, and autonomous recovery.

In conclusion, securing OT networks is both a technical and strategic imperative. By adopting proactive cybersecurity measures and resilience-focused strategies, industries can safeguard critical infrastructure against an evolving threat landscape. Lessons from past attacks, combined with innovative cybersecurity technologies, provide a roadmap for building a secure and resilient industrial future.

References

[1] M. Negi, Towards the integration of it/ot technologies in electricity based digitalized energy systems (2024).

[2] E. D. Knapp, Industrial Network Security: Securing critical infrastructure networks for smart grid, SCADA, and other Industrial Control Systems, Elsevier, 2024.

[3] T. Zaid, S. Garai, Emerging trends in cybersecurity: A holistic view on current threats, assessing solutions, and pioneering new frontiers, Blockchain in Healthcare Today 7 (2024).

[4] K. Kalinaki, Ransomware threat mitigation strategies for protecting critical infrastructure assets, in: Ransomware Evolution, CRC Press, 2025, pp. 120–143.

[5] S. A. Daniel, S. S. Victor, Emerging trends in cybersecurity for critical infrastructure protection: A comprehensive review, Computer Science & IT Research Journal 5 (2024) 576–593.

[6] M. Waqas, M. Jamil, Smart iot scada system for hybrid power monitoring in remote natural gas pipeline control stations, Electronics 13 (2024) 3235.

[7] S. Misbahuddin, Fault tolerant remote terminal units (rtus) in scada systems, in: 2010 International symposium on collaborative technologies and systems, IEEE, 2010, pp. 440–446.

[8] https://threatpost.com, black-hat-remote-dos-backdoor-easter-egg-among-newly-discovered-siemens-holes-080311, 2011. URL: https://threatpost.com/black-hat-remote-dos-backdoor-easter-egg-among-newly-discovered-siemens-holes-080311/75506/, accessed: 2024-08-19.

[9] building.enlyze.com, on-the-hype-around-the-critical-siemens-s7-1200-1500-vulnerability, 2019. URL: https://building.enlyze.com/posts/on-the-hype-around-the-critical-siemens-s7-1200-1500-vulnerabilit accessed: 2024-08-19.

[10] R. Langner, Stuxnet analysis by langner, 2013. URL: https://www.langner.com/wp-content/uploads/2017/03/to-kill-a-centrifuge.pdf, accessed: 2024-07-29.

[11] D. Kushner, The real story of stuxnet, ieee Spectrum 50 (2013) 48–53.

[12] J. P. Farwell, R. Rohozinski, Stuxnet and the future of cyber war, Survival 53 (2011) 23–40.

[13] L. M. D. Fargo, Stuxnet fact report, 2012. URL: https://ccdcoe.org/uploads/2018/10/Falco2012_StuxnetFactsReport.pdf, accessed: 2024-07-29.

[14] B. Stojanović, K. Hofer-Schmitz, U. Kleb, Apt datasets and attack modeling for automated detection methods: A review, Computers & Security 92 (2020) 101734.

[15] P. Kozak, I. Klaban, T. Šlajs, Industroyer cyber-attacks on ukraine's critical infrastructure, in: 2023 International Conference on Military Technologies (ICMT), IEEE, 2023, pp. 1–6.

[16] A. Cherepanov, Win32/industroyer - a new threat for industrial control systems, Online, 2017. URL: https://web-assets.esetstatic.com/wls/2017/06/Win32_Industroyer.pdf, accessed: 2024-02-18.

[17] D. I. . WWW.DRAGOS.COM, Crashoverride analysis of the threat to electric grid operations, Online, 2017. URL: https://www.dragos.com/wp-content/uploads/CrashOverride-01.pdf, accessed: 2024-07-29.

[18] S. ICS, Analysis of the cyber attack on the ukrainian power grid, Online, 2016. URL: https://media.kasperskycontenthub.com/wp-content/uploads/sites/43/2016/05/20081514/E-ISAC_SANS_Ukraine_DUC_5.pdf, accessed: 2024-07-29.

[19] Y. Mekdad, G. Bernieri, M. Conti, A. E. Fergougui, A threat model method for ics malware: the trisis case, in: Proceedings of the 18th ACM International Conference on Computing Frontiers, 2021, pp. 221–228.

[20] D. INC., Trisis malware : Analysis of safety system targeted malware, 2017. URL: https://www.dragos.com/wp-content/uploads/TRISIS-01.pdf, accessed: 2024-07-29.

[21] I. H. Sarker, Ai for enhancing ics/ot cybersecurity, in: AI-Driven Cybersecurity and Threat Intelligence: Cyber Automation, Intelligent Decision-Making and Explainability, Springer, 2024, pp. 137–152.

[22] M. Gimenez-Aguilar, J. M. De Fuentes, L. Gonzalez-Manzano, D. Arroyo, Achieving cybersecurity in blockchain-based systems: A survey, Future Generation Computer Systems 124 (2021) 91–118.

[23] D. Holmes, M. Papathanasaki, L. Maglaras, M. A. Ferrag, S. Nepal, H. Janicke, Digital twins and cyber security–solution or challenge?, in: 2021 6th South-East Europe Design Automation, Computer Engineering, Computer Networks and Social Media Conference (SEEDA-CECNSM), IEEE, 2021, pp. 1–8.

[24] N. Kashpruk, C. Piskor-Ignatowicz, J. Baranowski, Time series prediction in industry 4.0: A comprehensive review and prospects for future advancements, Applied Sciences 13 (2023) 12374.

[25] E. Bajramovic, Secure Logging in Operational Instrumentation and Control Systems, Ph.D. thesis, Friedrich-Alexander-Universität Erlangen-Nürnberg (FAU), 2019.

[26] R. Mustofa, M. Rafiquzzaman, N. U. I. Hossain, Analyzing the impact of cyber-attacks on the performance of digital twin-based industrial organizations, Journal of Industrial Information Integration 41 (2024) 100633.

[27] A. S. George, The impact of it/ot convergence on digital transformation in manufacturing, Partners Universal International Innovation Journal 2 (2024) 18–38.

[28] H. Vardhan, D. Hyde, U. Timalsina, P. Volgyesi, J. Sztipanovits, Sample-efficient and surrogate-based design optimization of underwater vehicle hulls, Ocean Engineering 311 (2024) 118777.

[29] H. Vardhan, N. Kumari, P. Volgyesi, J. Sztipanovits, Fusion of ml with numerical simulation for optimized propeller design, in: 2024 IEEE Workshop on Design Automation for CPS and IoT (DESTION), IEEE, 2024, pp. 22–27.

[30] H. Vardhan, J. Sztipanovits, Deep learning based fea surrogate for sub-sea pressure vessel, in: 2022 6th International Conference on Computer, Software and Modeling (ICCSM), IEEE, 2022, pp. 36–39.

[31] S. Kumar, H. Vardhan, S. Priya, A. Kumar, Malaria detection using deep convolution neural network, arXiv preprint arXiv:2303.03397 (2023).

[32] A. Ake, Enhancing us energy sector performance through advanced data-driven analytical frameworks (????).

[33] https://www.tdworld.com/, Duke energy's hybrid approach to ai, 2023. URL: https://www.tdworld.com/digital-innovations/article/21262976/duke-energys-hybrid-approach-to-ai, accessed: 2025-01-31.

[34] D. D. Jambol, O. O. Sofoluwe, A. Ukato, O. J. Ochulor, Transforming equipment management in oil and gas with ai-driven predictive maintenance, Computer Science & IT Research Journal 5 (2024) 1090–1112.

[35] A. Ahadov, Predictive maintenance model of rotating machinery using ai (2024).

[36] N. F. Syed, S. W. Shah, A. Shaghaghi, A. Anwar, Z. Baig, R. Doss, Zero trust architecture (zta): A comprehensive survey, IEEE access 10 (2022) 57143–57179.

[37] S. Russo, Industrial demilitarized zone and zero trust cybersecurity models for industrial control systems (????).

[38] H. Javed, Z. Abaid, S. Akbar, K. Ullah, A. Ahmad, A. Saeed, H. Ali, Y. Y. Ghadi, T. J. Alahmadi, H. K. Alkahtani, et al., Blockchain-based logging to defeat malicious insiders: The case of remote health monitoring systems, IEEE Access (2023).

[39] A. Baggio, F. Grimaccia, Blockchain as key enabling technology for future electric energy exchange: A vision, IEEE Access 8 (2020) 205250–205271.

[40] Y. Wang, Z. Su, S. Guo, M. Dai, T. H. Luan, Y. Liu, A survey on digital twins: Architecture, enabling technologies, security and privacy, and future prospects, IEEE Internet of Things Journal 10 (2023) 14965–14987.

[41] K. Wang, Q. Hu, M. Zhou, Z. Zun, X. Qian, Multi-aspect applications and development challenges of digital twin-driven management in global smart ports, Case Studies on Transport Policy 9 (2021) 1298–1312.

[42] L. Brüll, The Role of Digital Twins on Rail Operations at EU Container Terminals: Crucial or Negligible?, B.S. thesis, University of Twente, 2024.

[43] A. Z. M. N. Abir, Industry 4.0 technologies for a data-driven, secure, green and circular manufacturing economy, in: 2024 IEEE Green Technologies Conference (GreenTech), IEEE, 2024, pp. 26–31.

[44] G. Restuccia, H. Tschofenig, E. Baccelli, Low-power iot communication security: On the performance of dtls and tls 1.3, in: 2020 9th IFIP International Conference on Performance Evaluation and Modeling in Wireless Networks (PEMWN), IEEE, 2020, pp. 1–6.

[45] P. Nutalapati, Automated incident response using ai in cloud security, Journal of Artificial Intelligence, Machine Learning and Data Science 2 (2024) 1301–1311.

[46] S. He, Z. Li, J. Wang, N. N. Xiong, Intelligent detection for key performance indicators in industrial-based cyber-physical systems, IEEE Transactions on Industrial Informatics 17 (2020) 5799–5809.

[47] C. Zhou, B. Hu, Y. Shi, Y.-C. Tian, X. Li, Y. Zhao, A unified architectural approach for cyberattack-resilient industrial control systems, Proceedings of the IEEE 109 (2020) 517–541.

[48] H. I. Kure, S. Islam, M. A. Razzaque, An integrated cyber security risk management approach for a cyber-physical system, Applied Sciences 8 (2018) 898.

[49] P. Garcia-Teodoro, J. Diaz-Verdejo, G. Maciá-Fernández, E. Vázquez, Anomaly-based network intrusion detection: Techniques, systems and challenges, computers & security 28 (2009) 18–28.

[50] N. Moustafa, J. Slay, The evaluation of network anomaly detection systems: Statistical analysis of the unsw-nb15 data set and the comparison with the kdd99 data set, Information Security Journal: A Global Perspective 25 (2016) 18–31.

[51] R. Vinayakumar, M. Alazab, K. P. Soman, P. Poornachandran, A. Al-Nemrat, S. Venkatraman, Deep learning approach for intelligent intrusion detection system, IEEE access 7 (2019) 41525–41550.

[52] D. Shalyga, P. Filonov, A. Lavrentyev, Anomaly detection for water treatment system based on neural network with automatic architecture optimization, CoRR abs/1807.07282 (2018). URL: `http://arxiv.org/abs/1807.07282`. `arXiv:1807.07282`.

[53] S. Bellamkonda, Cybersecurity in critical infrastructure: Protecting the foundations of modern society, International Journal of Communication Networks and Information Security 12 (2020) 273–280.

[54] S. S. Fortunato, Risk Management in ICS/SCADA Systems to Enhance Security within the Energy Sector, Master's thesis, Utica College, 2020.

[55] T. Qiu, J. Chi, X. Zhou, Z. Ning, M. Atiquzzaman, D. O. Wu, Edge computing in industrial internet of things: Architecture, advances and challenges, IEEE Communications Surveys & Tutorials 22 (2020) 2462–2488.

[56] J. Lanz, The updated nist cybersecurity framework, The CPA Journal 94 (2024) 70–72.

[57] M. Hätinen, Evolution of cybersecurity risk management standardization: Comparison of the nist cybersecurity framework version 1.1 and 2.0 (2024).

[58] C. Varol, Enhancing and Adapting Security Risk Assessment Strategies on Critical Infrastructure Utilizing IoT Devices using NIST Cybersecurity Framework 2.0, Technical Report, Institute for Homeland Security, 2024.

[59] J. Martínez, J. M. Durán, Software supply chain attacks, a threat to global cybersecurity: Solarwinds' case study, International Journal of Safety and Security Engineering 11 (2021) 537–545.

[60] A. Robinson, C. Corcoran, J. Waldo, New risks in ransomware: Supply chain attacks and cryptocurrency, Science, Technology, and Public Policy Program Reports (2022).

[61] A. Damaraju, Implementing zero trust architecture in modern cyber defense strategies, Unique Endeavor in Business & Social Sciences 3 (2024) 173–188.

[62] W. ALMUSEELEM, Continuous and mutual lightweight authentication for zero-trust architecture-based security framework in cloud-edge computing-based healthcare 4.0, Journal of Theoretical and Applied Information Technology 102 (2024).

[63] A. T. Xun, L. A. Z. En, L. T. Shen, A. N. Xin, W. H. Soon, W. Z. Jun, H. Ramachandra, G. Xinghao, N. M. Khant, F. Weitao, et al., Building trust in cloud computing: Strategies for resilient security (2025).

[64] E. B. Fernandez, A. Brazhuk, A critical analysis of zero trust architecture (zta), Computer Standards & Interfaces 89 (2024) 103832.

[65] C. Sample, C. Shelton, S. M. Loo, C. Justice, L. Hornung, I. Poynter, Zta: Never trust, always verify, in: ECCWS 2022 21st European Conference on Cyber Warfare and Security, Academic Conferences and publishing limited, 2022.

[66] csoonline.com, Most organizations globally have implemented zero trust, 2023. URL: `https://www.csoonline.com/article/656108/most-organizations-globally-have-implemented-zero-trust.html?`, accessed: 2025-01-28.

[67] okta.com, The state of zero trust security 2023, 2023. URL: `https://www.okta.com/resources/whitepaper-the-state-of-zero-trust-security-2023/`, accessed: 2025-01-28.

[68] P. O'Reilly, K. Rigopoulos, Fiscal year 2023 cybersecurity and privacy annual report, NIST SPECIAL PUBLICATION 800 (2024) 229.

[69] M. Kallatsa, Strategies for network segmentation: a systematic literature review (2024).

[70] D. C. Mazur, R. A. Entzminger, P. A. Morell, J. A. Kay, E. Syme, Defining the industrial demilitarized zone and its benefits for mining applications, IEEE Transactions on Industry Applications 52 (2016) 2731–2736.

[71] Y. Heo, B. Kim, D. Kang, J. Na, A design of unidirectional security gateway for enforcement reliability and security of transmission data in industrial control systems, in: 2016 18th International Conference on Advanced Communication Technology (ICACT), IEEE, 2016, pp. 310–313.

[72] M. Guri, Air-gap electromagnetic covert channel, IEEE Transactions on Dependable and Secure Computing (2023).

[73] J.-w. Myung, S. Hong, Ics malware triton attack and countermeasures., IJEMR 3 (2019) 13–17.

[74] G. M. Makrakis, C. Kolias, G. Kambourakis, C. Rieger, J. Benjamin, Vulnerabilities and attacks against industrial control systems and critical infrastructures, arXiv preprint arXiv:2109.03945 (2021).

[75] M. D. Firoozjaei, N. Mahmoudyar, Y. Baseri, A. A. Ghorbani, An evaluation framework for industrial control system cyber incidents, International Journal of Critical Infrastructure Protection 36 (2022) 100487.

[76] https://webstore.iec.ch/, Iec 62443-2-1, 2024. URL: `https://webstore.iec.ch/en/publication/62883`, accessed: 2025-01-28.

[77] https://webstore.iec.ch/, Isa/iec 62443 series of standards; the world's only consensus-based automation and control systems cybersecurity standards, 2024. URL: `https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards`, accessed: 2025-01-28.

[78] B. Leander, A. Čaušević, H. Hansson, Applicability of the iec 62443 standard in industry 4.0/iiot, in: Proceedings of the 14th International Conference on Availability, Reliability and Security, 2019, pp. 1–8.

[79] C. Göttel, M. Kabir-Querrec, D. Kozhaya, T. Sivanthi, O. Vuković, Qualitative analysis for validating iec 62443-4-2 requirements in devsecops, in: 2023 IEEE 28th International Conference on Emerging Technologies and Factory Automation (ETFA), IEEE, 2023, pp. 1–8.

[80] M. P. Heinl, M. Pursche, N. Puch, S. N. Peters, A. Giehl, From standard to practice: Towards isa/iec 62443-conform public key infrastructures, in: International Conference on Computer Safety, Reliability, and Security, Springer, 2023, pp. 196–210.

[81] F. Moyón, R. Soares, M. Pinto-Albuquerque, D. Mendez, K. Beckers, Integration of security standards in devops pipelines: An industry case study, in: Product-Focused Software Process Improvement: 21st International Conference, PROFES 2020, Turin, Italy, November 25–27, 2020, Proceedings 21, Springer, 2020, pp. 434–452.

[82] D. Oberhofer, M. Hornsteiner, S. Schönig, Market research on iiot standard compliance monitoring providers and deriving attributes for iiot compliance monitoring, arXiv preprint arXiv:2311.09991 (2023).

[83] Fortinet, Fortinet 2024 state of ot cybersecurity report, https://www.fortinet.com/resources/cyberglossary/state-of-ot-cybersecurity-report, 2024. Accessed: 2025-02-10.

[84] Dragos, M. McLennan, The economic impact of ot cyber risk, https://www.dragos.com/resources/ot-cyber-risk-report/, 2024. Accessed: 2025-02-10.

[85] K. Lab, Kaspersky industrial cybersecurity report 2024, https://ics-cert.kaspersky.com/reports/, 2024. Accessed: 2025-02-10.

[86] T. Guardian, Colonial pipeline confirms it paid $4.4m ransom to hacker gang after attack, https://www.theguardian.com/technology/2021/may/19/colonial-pipeline-cyber-attack-ransom, 2021. Accessed: 2025-02-10.

[87] Cybersecurity, I. S. A. (CISA), The attack on colonial pipeline: What we have learned and what we have done over the past two years, https://www.cisa.gov/news-events/news/attack-colonial-pipeline-what-weve-learned-what-weve-done-over-past-two-years, 2023. Accessed: 2025-02-10.

[88] I. Security, X-force threat intelligence index 2025, https://www.ibm.com/reports/threat-intelligence, 2025. Accessed: 2025-10-27.

[89] Claroty, State of cyber-physical systems security 2024 — healthcare, https://claroty.com/resources/reports, 2024. Accessed: 2025-10-27.

[90] N. I. of Standards, Technology, Nist sp 1800-8: Securing wireless infusion pumps, https://www.nccoe.nist.gov/projects/building-blocks/securing-wireless-infusion-pumps, 2022. Accessed: 2025-10-27.

[91] C. Health, Commonspirit health annual report (form 10-k), https://www.sec.gov/edgar/search/entityName=CommonSpi 2023. Accessed: 2025-10-27.

[92] G. of Ireland, Hse ransomware attack: Post-incident review, https://www.gov.ie/, 2022. Accessed: 2025-10-27.

[93] I. E. Commission, Iec 80001-1:2023 — application of risk management for it-networks incorporating medical devices, https://webstore.iec.ch/, 2023. Accessed: 2025-10-27.

[94] U. Food, D. Administration, Cybersecurity in medical devices: Refuse-to-accept policy, https://www.fda.gov/medical-devices/cybersecurity, 2023. Accessed: 2025-10-27.